

Unidad 8:

Seguridad

Seguridad y VPNs - Resumen

- **Introducción. Normas seguridad**
- **Hashing**
- **Autenticación y firma digital**
- **PKI. Kerberos**
- **IPSec y VPN**
- **Firewalls e IDS.**
- **SSL. PGP**
- **Ejemplos de ataques/vulnerabilidades**
- **Resumen y referencias**

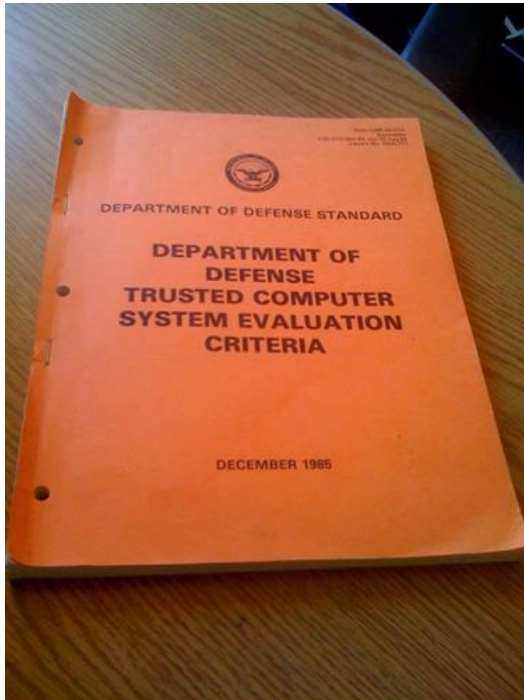
Repaso

- **Principios de seguridad**
- **Criptografía**
- **Clave pública y privada**
- **Algoritmos simétricos**
- **Algoritmos asimétricos**

Seguridad informática

- Primer paso: DEFINICION DE POLITICAS!!!
- Activos a resguardar (información estratégica, datos personales). Imposiciones legales
- Gran problema: que hacer con la información?
- Ocultarla? -> no podemos usarla.
- Compartirla? Corremos riesgos de que llegue a manos incorrectas (Wikileaks)
- Costo de las medidas
- Mejores prácticas
- Niveles de trabajo
- Legislación internacional (HIPAA en USA)
- Argentina: Ley 24.766
- <http://www.informatica-juridica.com/legislacion/argentina/>
- Normas ISO 27001 y 27002
- Temas desarrollados en materia específica

Seguridad informática



Los libros de la Serie Arcoiris (Rainbow Series) componen una colección de volúmenes sobre estándares y directrices de seguridad informática editados por el gobierno de los Estados Unidos de América entre 1983 y 1993.

Todos los tomos tenían una portada de un vivo color distinto, de ahí el nombre de la serie (Arcoiris), y cada uno de ellos era conocido por el color de su portada. El titulado 'DoD Trusted Computer System Evaluation Criteria', TCSEC, (Criterios de evaluación de un sistema informático de confianza), que fue el primero de los volúmenes publicado (1983), era mundialmente conocido como el Libro Naranja (Orange Book), pues así era el color de su portada.

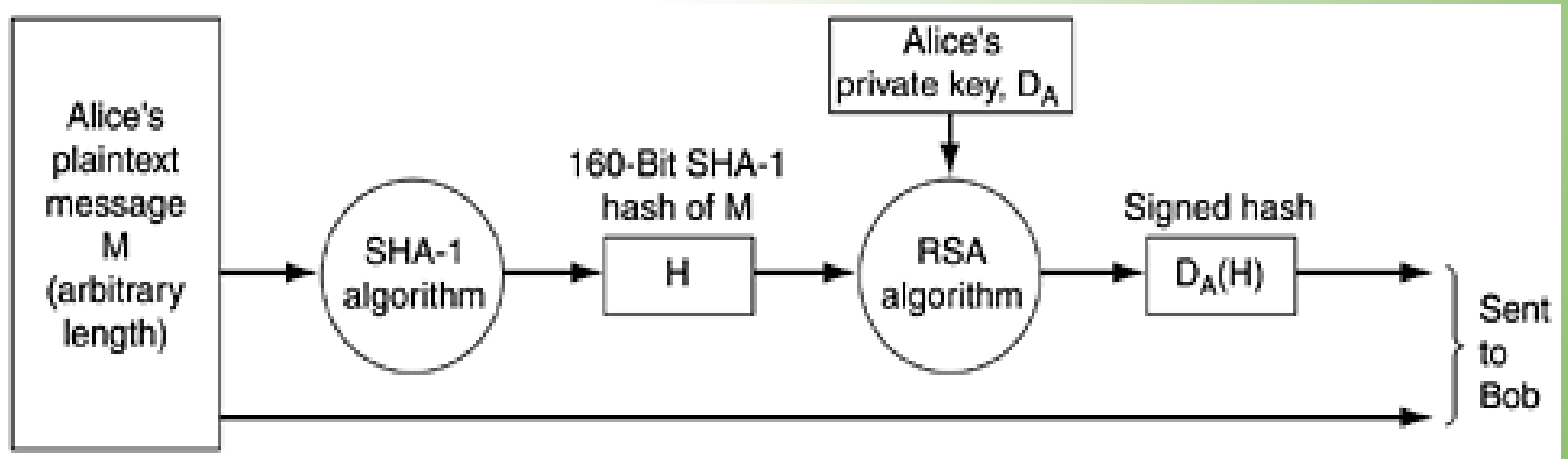
Según la norma ISO 27002 (2005), la seguridad de la información es la protección de la información contra todo tipo de amenazas, y tiene la finalidad de asegurar la continuidad del negocio, con el objeto de maximizar el retorno de la inversión y las oportunidades de negocio. Todas las obras humanas son falibles, por lo que es frecuente conseguir puntos de falla en toda la tecnología relacionada con la información, sin embargo, aunque es inevitable la ocurrencia de fallas, ello no implica que se asuman conductas de resignación, de esa actitud surge el concepto de seguridad de la información, como la vía para hacer frente, para prever y evitar errores o ataques.

Seguridad informática

- Norma ISO 27002
- La norma ISO 27002 (anteriormente denominada ISO 17799) es un estándar para la seguridad de la información que ha publicado la organización internacional de normalización y la comisión electrotécnica internacional. La versión más reciente de la norma ISO 27002:2013.
- La norma ISO 27002 proporciona diferentes recomendaciones de las mejores prácticas en la gestión de la seguridad de la información a todos los interesados y responsables para iniciar, implementar o mantener sistemas de gestión de la seguridad de la información. La seguridad de la información se define en el estándar como “la preservación de la confidencialidad, integridad y disponibilidad. Para saber más sobre los demás dominios puede leer La norma ISO 27002 complemento para la ISO 27001.
- La norma ISO 27002 se encuentra enfocada a todo tipo de empresas, independientemente del tamaño, tipo o naturaleza.
- La norma ISO 27002 se encuentra organizado en base a los 14 dominios, 35 objetivos de control y 114 controles.
- El documento denominado política es aquel que expresa una intención e instrucción general de la forma que ha sido expresada por la dirección de la empresa.
- El contenido de las políticas se basa en el contexto en el que opera una empresa y suele ser considerado en su redacción todos los fines y objetivos de la empresa, las estrategias adoptadas para conseguir sus objetivos, la estructura y los procesos utilizados por la empresa. Además, de los objetivos generales y específicos relacionados con el tema de la política y los requisitos de las políticas procedentes de niveles superiores y que se encuentran relacionadas.

- Hashing: función resumen
- Unidireccional: $P \rightarrow MD(P)$ fácil; $MD(P) \rightarrow P$ imposible.
- $\nexists P, P' / MD(P) = MD(P')$ (colisión) – Ataque cumpleaños. Long. clave > 128 bits
- Pocos cambios en $P \rightarrow$ muchos cambios en $MD(P)$
- Los algoritmos deben ser más eficientes y rápidos que los usados en algoritmos simétricos
- Protocolos: BLAKE2, SHA2/3. MD5/SHA-0/1 se consideran vulnerables.
- Se utiliza en FIRMA DIGITAL, cuando importa más la AUTENTICIDAD y el NO REPUDIO que la CONFIDENCIALIDAD. Ejemplo.
- Se envía P y un hash $MD(P)$ firmado con la clave del emisor; el receptor al desenscriptar puede constatar la veracidad
- Se puede usar con clave pública o privada

Ejemplo con SHA-1 y clave pública



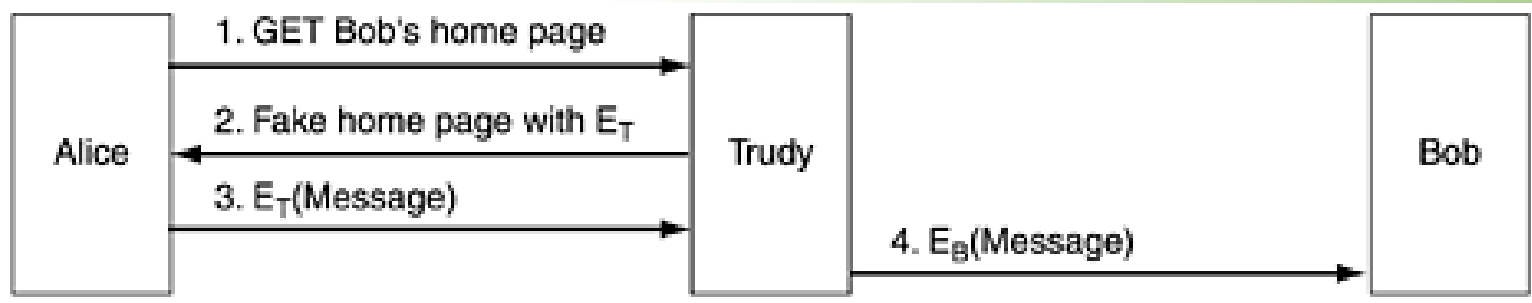
- Encriptamos con CLAVE PRIVADA
- Desencriptamos con PUBLICA
- Recordemos que:
$$E(D(P)) = D(E(P)) = P$$

Comparación MD5 y SHA-1

Característica	MD5	SHA-1
Longitud	128 bits	160 bits
Probabilidad colisiones (ataque cumpleaños)	2^{64}	2^{80}
Bloque	512 bits	512 bits
Funciones de generación	4	4
Cantidad de pasos	64	80
Longitud máxima del mensaje	Ilimitado	2^{64} bits
Constantes utilizadas	64	4
Seguridad	Inseguro	Poco seguro

PKI – Public Key Infrastructure

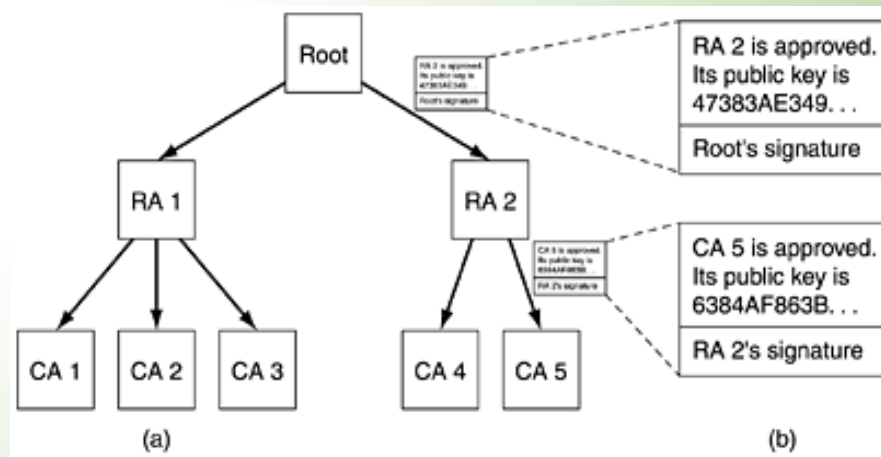
- Problema: la clave pública del receptor es válida?
- Problema MITM. Ejemplo



- Solución: una CA que emita certificados (C) firmados con la clave privada del receptor
- Se calcula $D(\text{MD}(C))$ del certificado y se adjunta al certificado. El receptor calcula $E(D(\text{MD}(C)))$, obtiene $\text{MD}(C)$ y lo compara con el hash del certificado
- Si coincide, estamos seguros de estar usando la clave pública correcta
- Formato estándar de certificados (p.ej. X.509)

PKI – Public Key Infrastructure

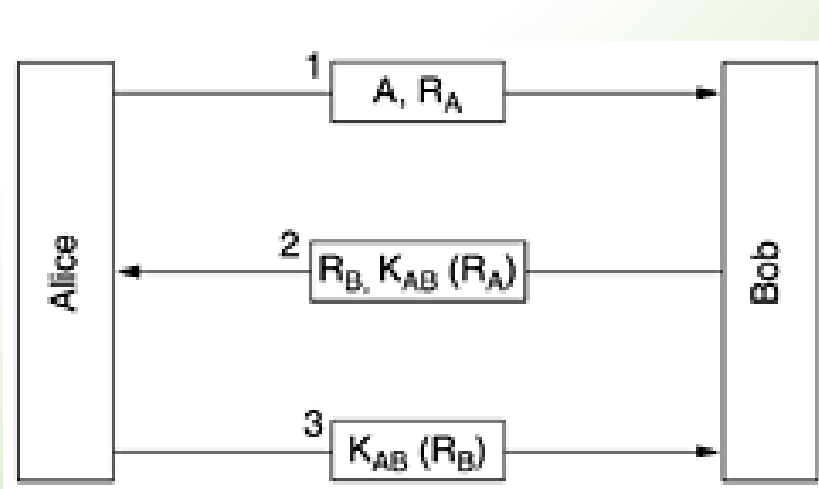
- Ahora bien: cómo valido la CA?
- No es conveniente una CA centralizada
- Solución: cadena de confianza (o de certificados)



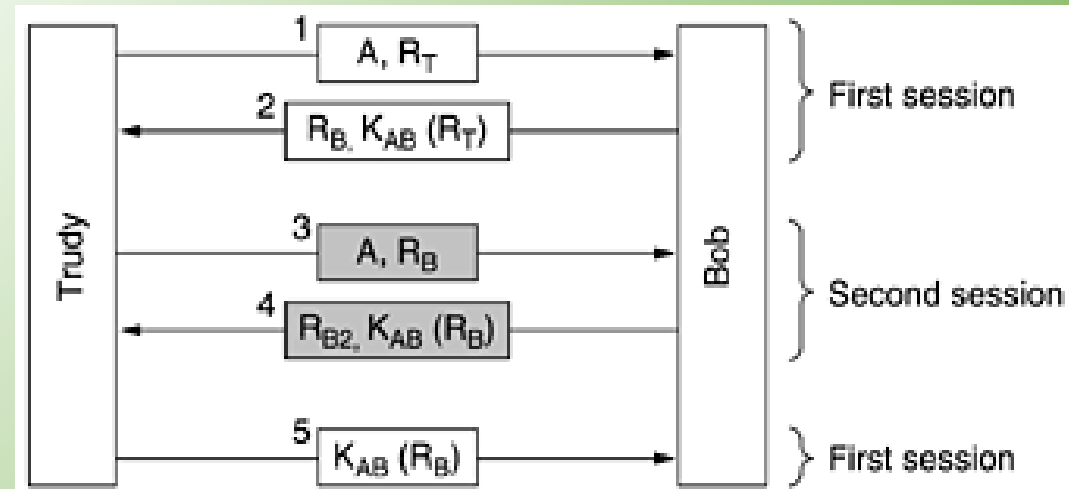
- Jerarquía descentralizada: CA, RA, Root
- Se puede proveer la cadena completa al momento de certificar
- Las Root pueden venir incluidas en la aplicación (p.ej. navegador)
- Hay que prever las revocaciones → CRL

Esquemas de Autenticación

- Un problema equivalente para claves privadas.
- Un protocolo sencillo se basa en el intercambio de desafíos (nros aleatorios) y el uso de una clave de sesión precompartida
- Pero es vulnerable al ataque por reflexión



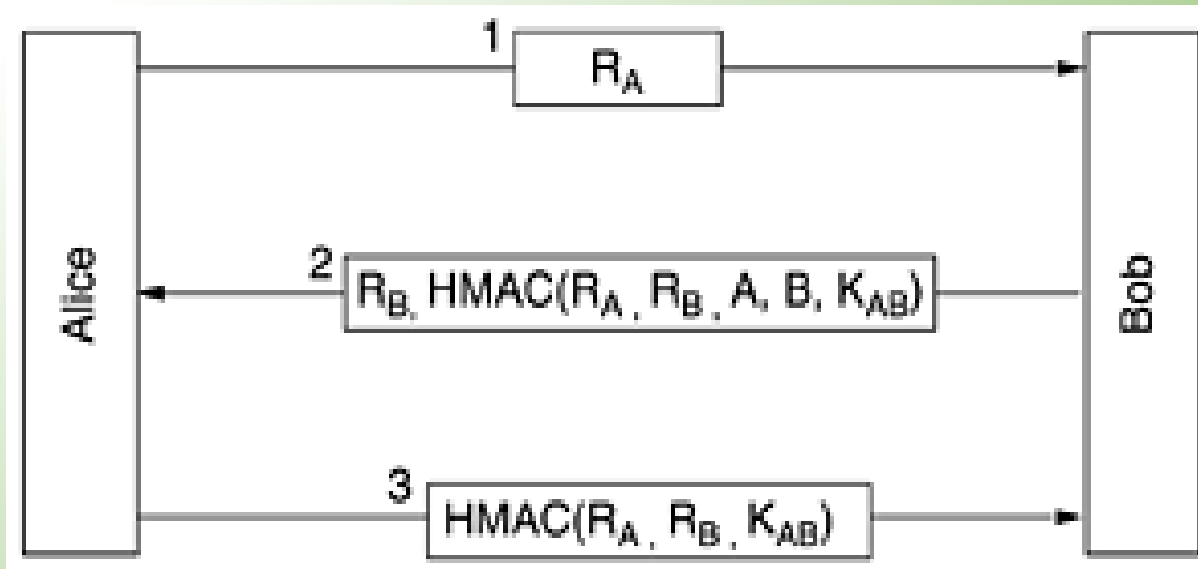
Protocolo



Ataque por reflexión

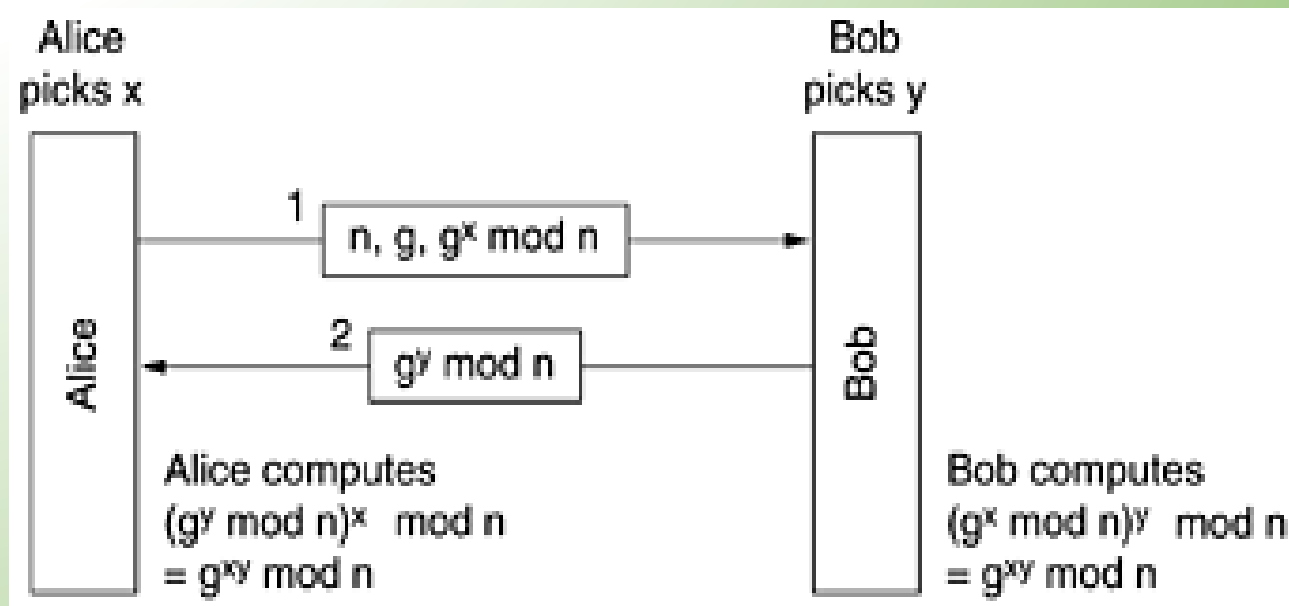
Esquemas de Autenticación

- Para solucionarlo, se utiliza HMAC (Hashed Message Authentication Code). Utilizado en IPSec
- Calcula el hash y lo autentica usando la clave precompartida en una sola pasada
- Más rápido que hacer MD5/SHA-1 y luego encriptar (RSA, DES, 3DES, etc.)



Distribución de claves

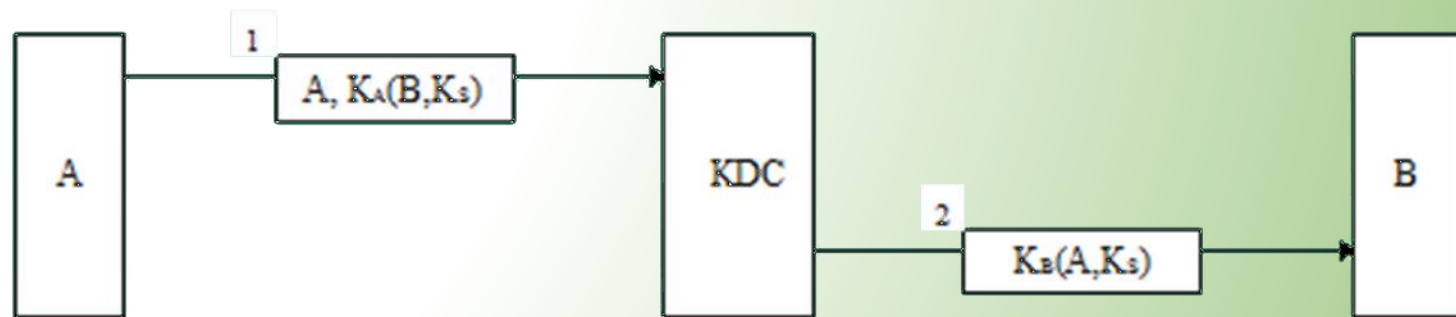
- Qué pasa si A y B no poseen una clave en común?
- Se puede generar mediante Diffie-Hellmann
- Por propiedades, dados g y n primos fuertes:
 $(g^x \bmod n)^y \bmod n = (g^y \bmod n)^x \bmod n = g^{xy} \bmod n = \mathbf{Z}$
- Este es el valor usado como clave
- Recordemos: es casi imposible factorizar un número grande en forma rápida



Distribución de claves

- DH es vulnerable a MITM.
- Además no sirve para distribuir claves simétricas
- Un enfoque diferente es el de KDC.
- Integra las funciones de autenticación y distribución de claves
- Utiliza las claves almacenadas para generar claves de sesión
- Las claves de los usuarios NUNCA son expuestas en el tránsito
- Timestamps para evitar ataques por repetición
- Se otorga un ticket para autenticar cada sesión
- Validez en un determinado ámbito
- Ejemplo: Kerberos

Validación de identificación usando un centro de distribución de claves (*KDC*): la rana de boca amplia



- 1.- A escoge una clave de sesión, K_s e indica al KDC que desea hablar con B usando K_s . Este mensaje se cifra con la clave secreta que comparte A sólo con el KDC, K_A .
- 2.- KDC descifra este mensaje, extrayendo la identidad de B y la clave de sesión. Construye un mensaje nuevo cifrado con K_B (compartido entre KDC y B) que contiene la identidad de A y la clave de sesión y se lo envía a B.

Ahora, A y B pueden hablar y saben además la clave a utilizar.

La validación de identificación aquí es gratuita, en el sentido que las claves con el KDC son secretas y nadie más habría sido capaz de cifrarlo con la clave secreta de otro.

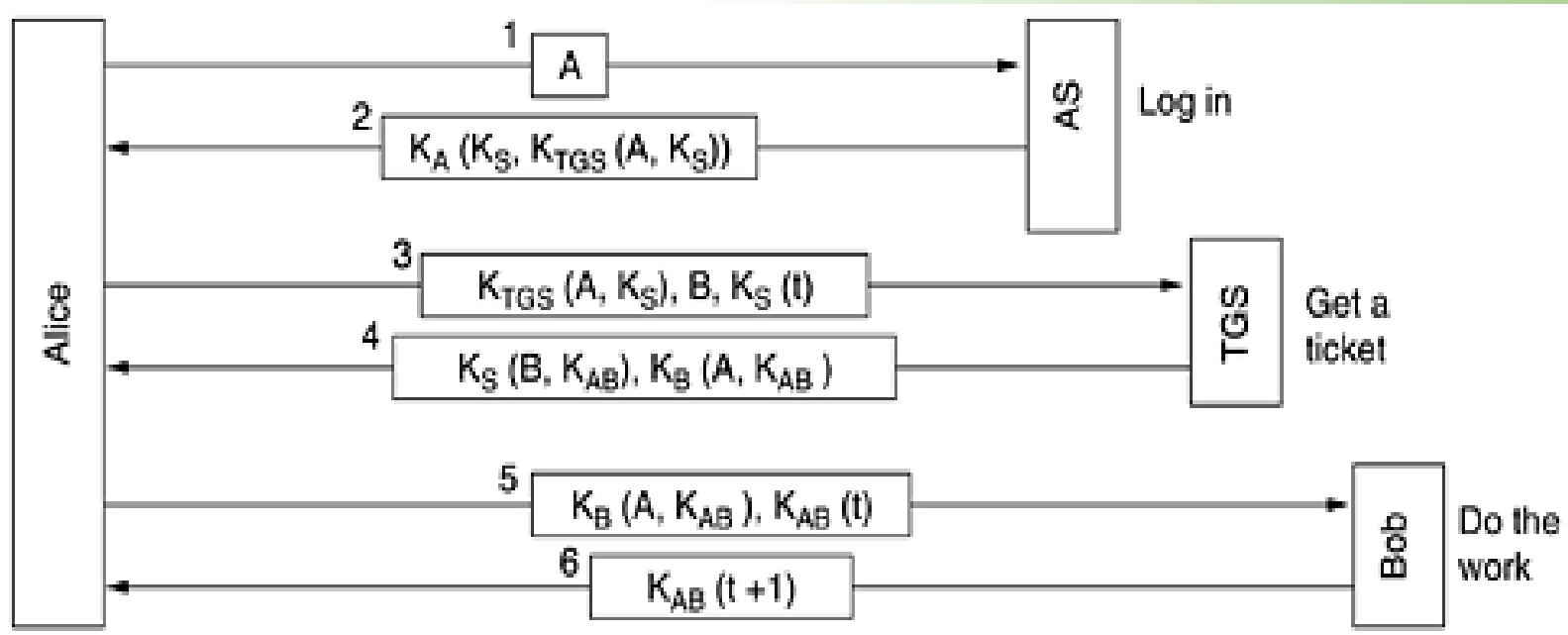
A diferencia de Diffie Hellman, aquí si existe autenticación por ambas partes.

Kerberos

Características:

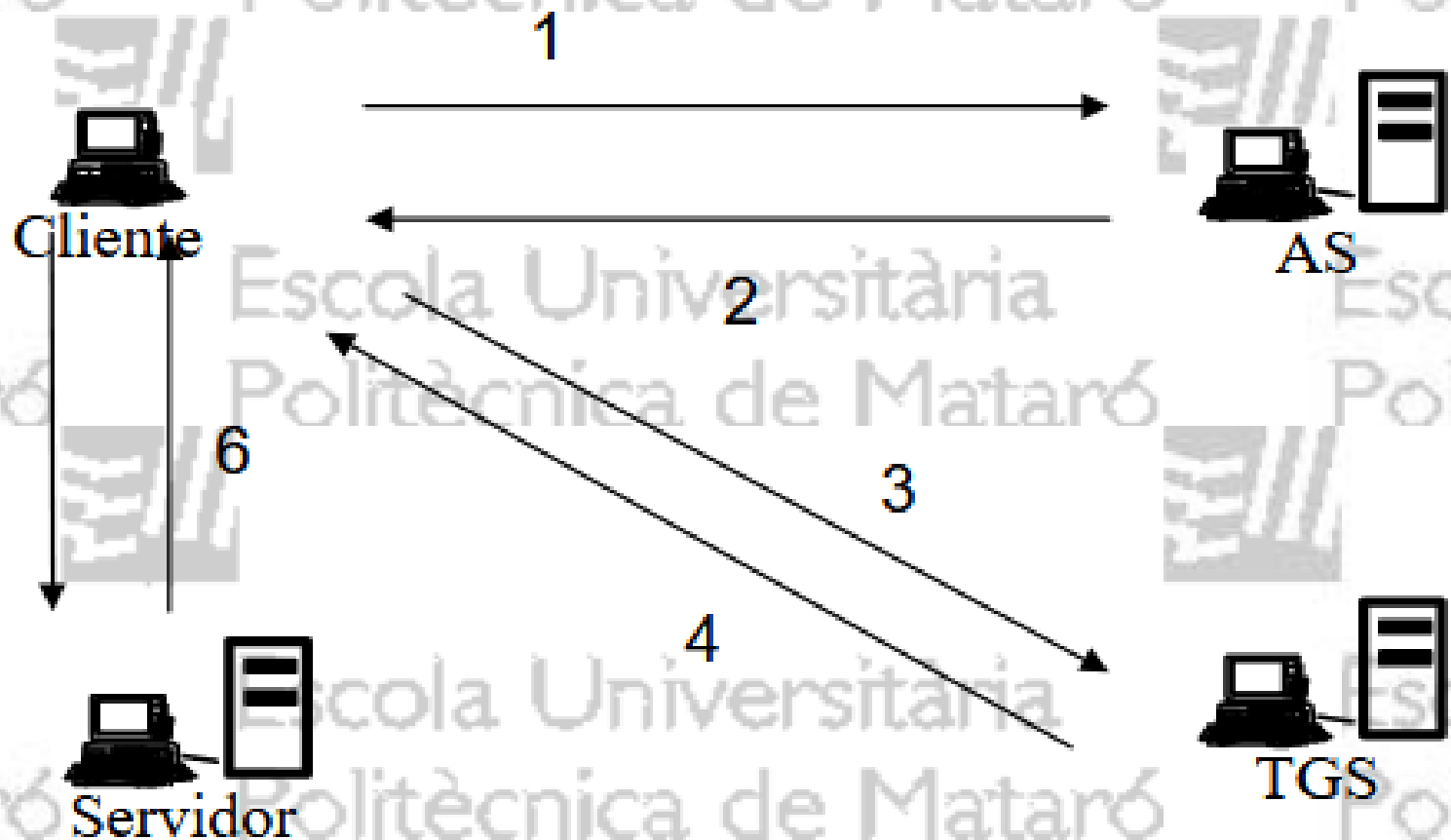
- Utiliza únicamente clave simétrica
- .Los passwords nunca viajan por la red.
- Se utiliza control de accesos individualizado para cada servicio, pero sólo se introduce el password una vez por sesión
- .Se puede separar la red en diferentes dominios físicos de seguridad.
- Basa el control de accesos en un sistema (hardware y software), llamado Servidor de Autenticación AS, diferente de los servidores de información
- .En la versión 4 utiliza el algoritmo DES, en la 5 permite cualquier algoritmo y cualquier longitud de clave.

Kerberos



- Existen mecanismos similares desarrollados para autenticar mediante clave pública

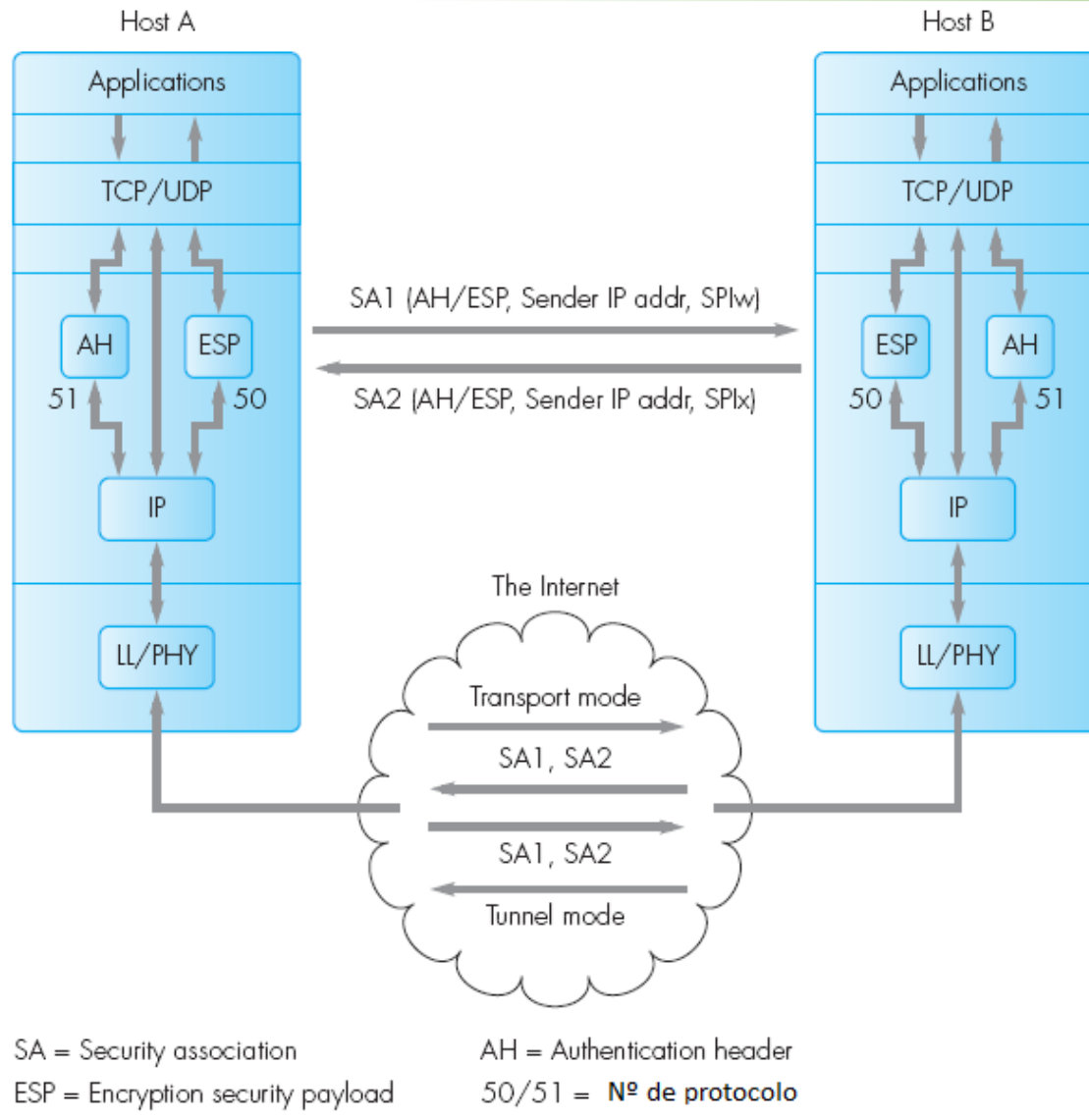
KERBEROS



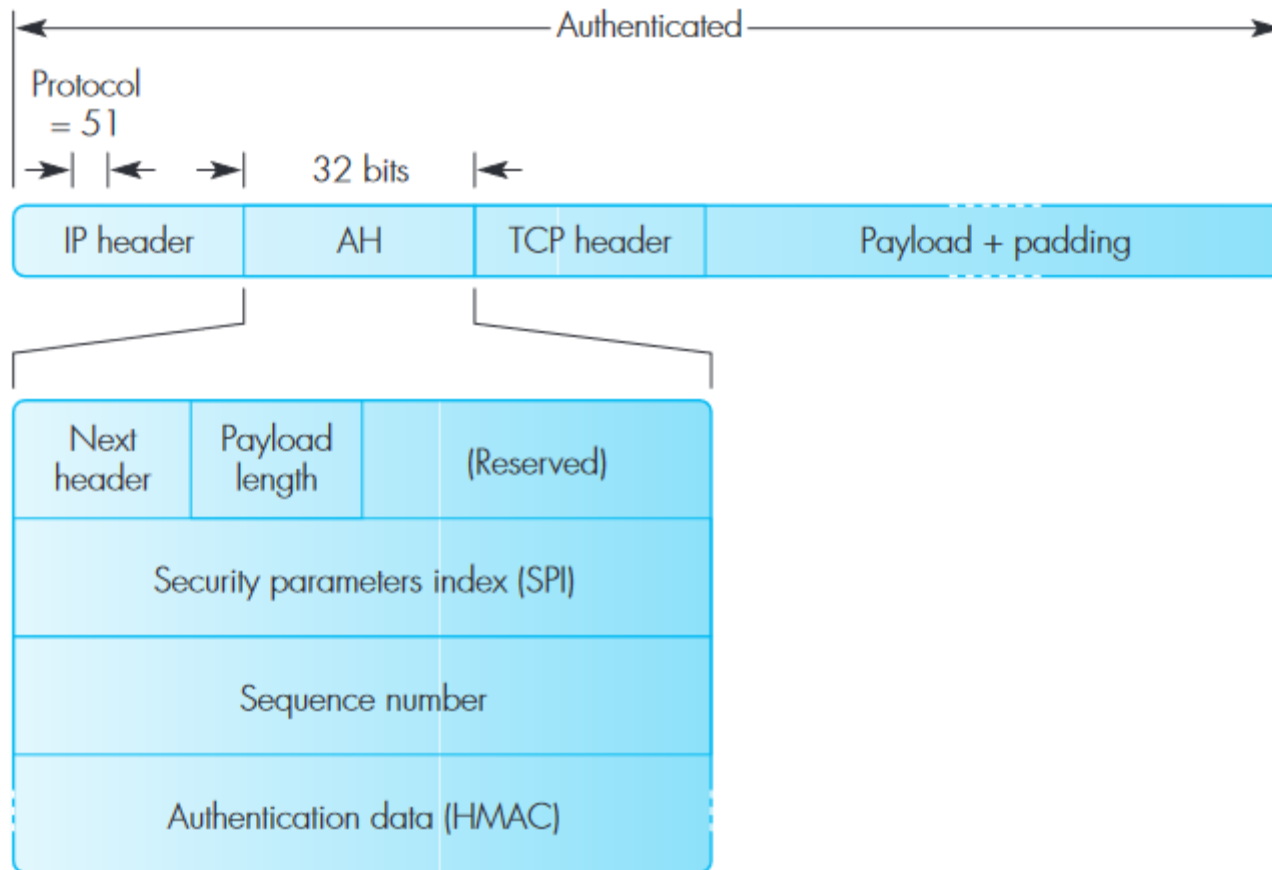
IPSec

- Protocolo de seguridad IP
- Brinda servicios de:
 - a) Autenticación (AH) (AUTHENTICATION HEADER)
 - b) Autenticación + encriptación (ESP)(ENCRYPTION SECURITY PAYLOAD)
 - c) Distribución de claves (IKE, Internet Key Exchange), ISAKMP (Internet Security Association and Key Management Protocol), Oakley)
- Se establece una asociación de seguridad (SA), unidireccional, entre ambos extremos
- Los extremos finales pueden ser hosts, o dispositivos intermedios (routers, firewalls, etc.)
- Puede operar en:
 1. Modo túnel: se arma un nuevo DG que encapsula al original IPSec.
 2. Modo transporte: se agrega cabecera de seguridad al DG original

IPSec – Esquema



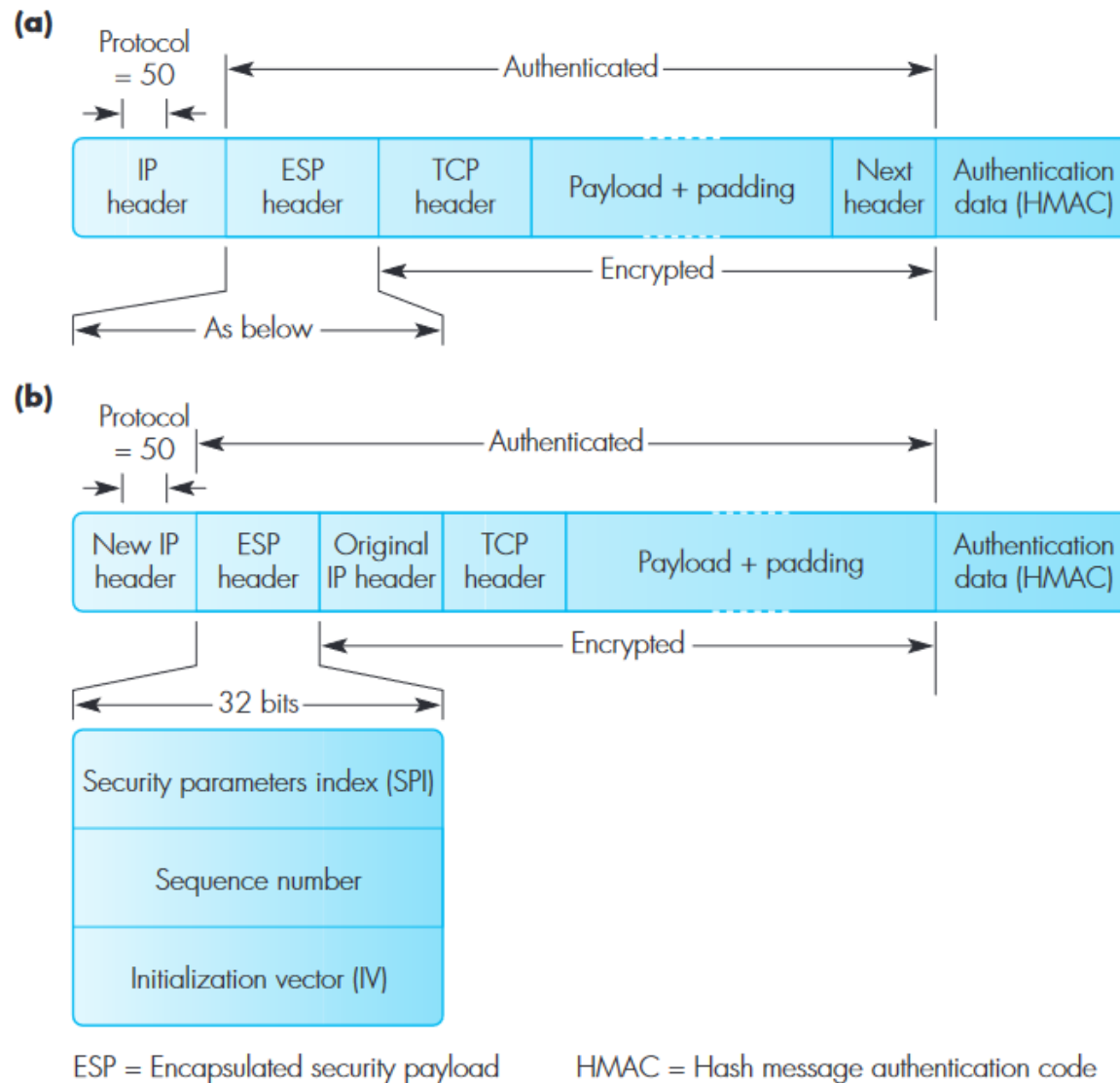
IPSec Protocolo de Cabecera de Autenticación



AH = Authentication header

HMAC = Hash message authentication code

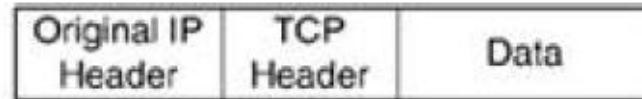
IPSec Protocolo de Encabezado de Seguridad



IPSec

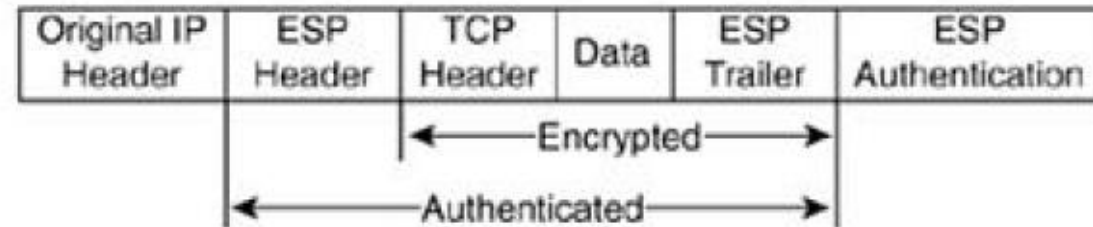
- Concepto clave: Asociación de Seguridad (SA)
- IPSec no define los algoritmos de encriptación o autenticación a utilizar (RFC 2403/04/05)
- En vez de ello, define una SPI (Security Parameter Index) negociado entre ambas entidades
- Este SPI agrupa los atributos de seguridad usados (p.ej. algoritmo de encriptación/ autenticación, long. de la clave, duración de la SA, direcciones, etc)
- Una SA se define mediante: modo IPSEC utilizado (AH ó ESP); SPI; y dirección destino
- Es UNIDIRECCIONAL

IPSec – AH y ESP modo túnel y transporte

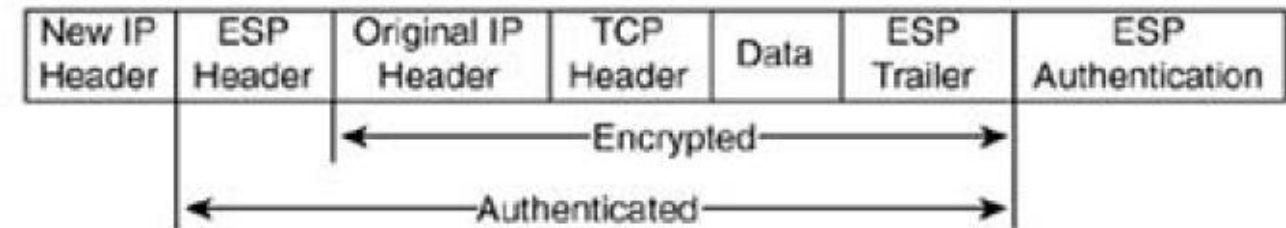


ESP

Transport Mode

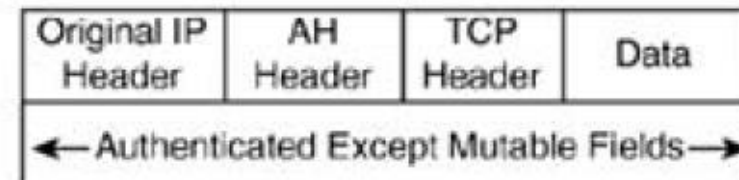


Tunnel Mode

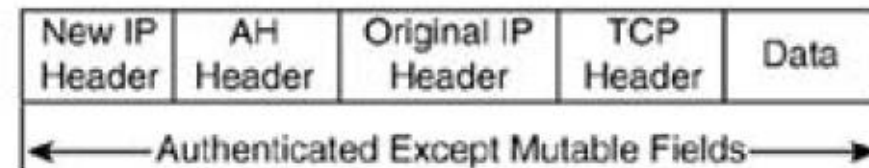


AH

Transport Mode



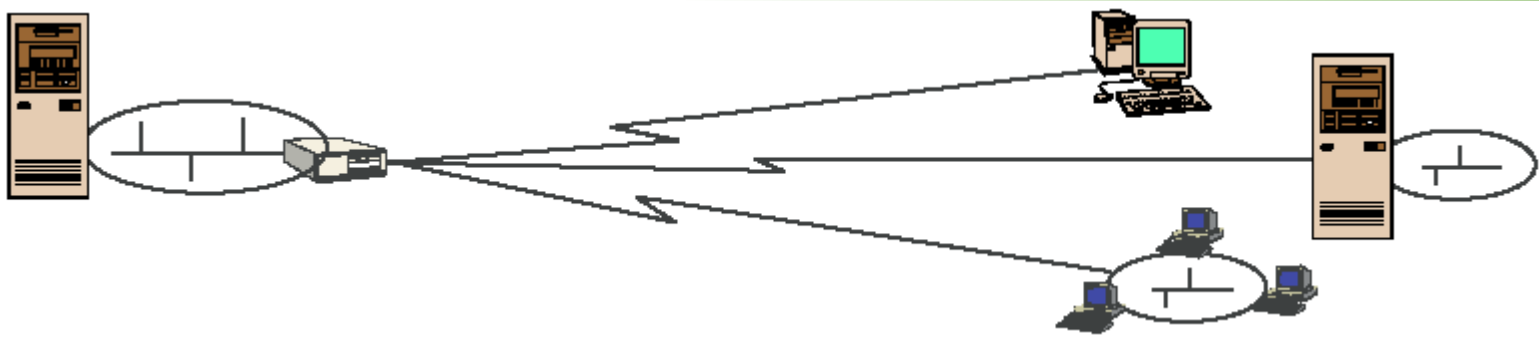
Tunnel Mode



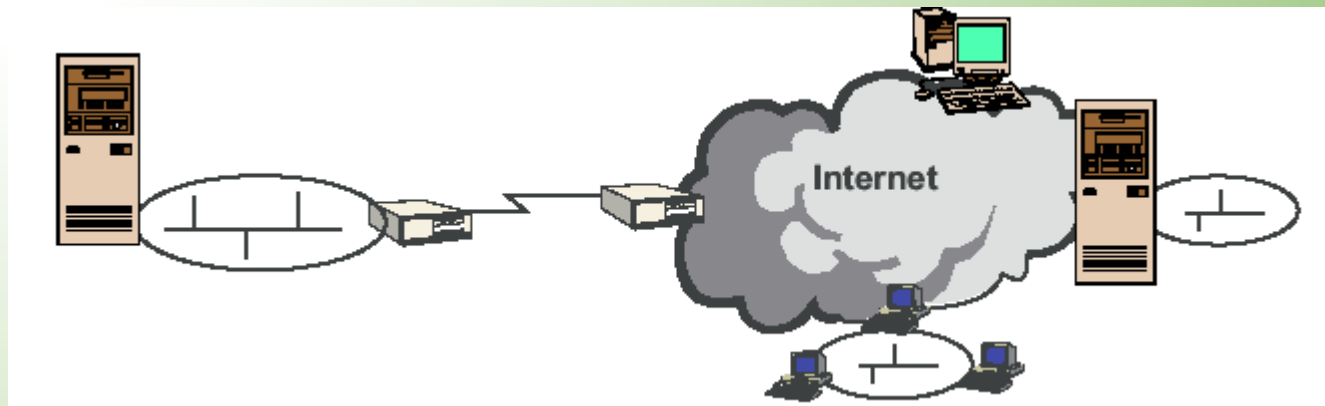
IPSec – Intercambio y distribución de claves

- **IPSec se puede configurar manualmente en cada router**
- **Pero es evidente la necesidad de un mecanismo escalable y flexible**
- **RFC 2409 propone IKE, que integra ISAKMP (claves) y OAKLEY (distribución)**
- **Aunque se puede utilizar cualquier otro esquema de infraestructura de seguridad (p.ej. PKI)**

Qué es una VPN?



Tradicionalmente, para conectar redes de la misma organización ubicadas en distintos puntos geográficos (ej branch/main office), se utilizan un conjunto de enlaces dedicados (ej. FR, ATM,...) con un costo relativamente alto



Una VPN reemplaza lo anterior, utilizando la Internet pública. La performance, el costo y la disponibilidad dependen del ISP seleccionado.

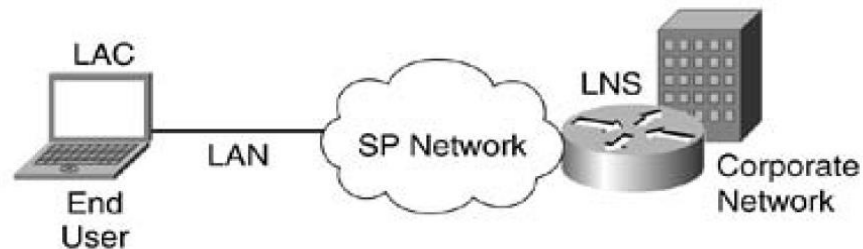
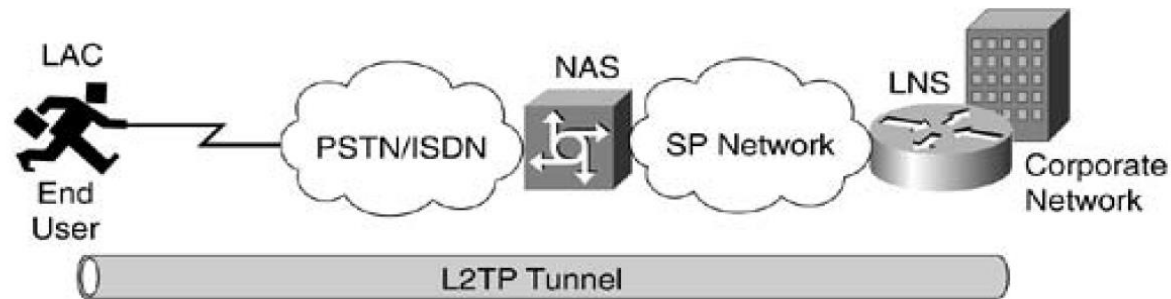
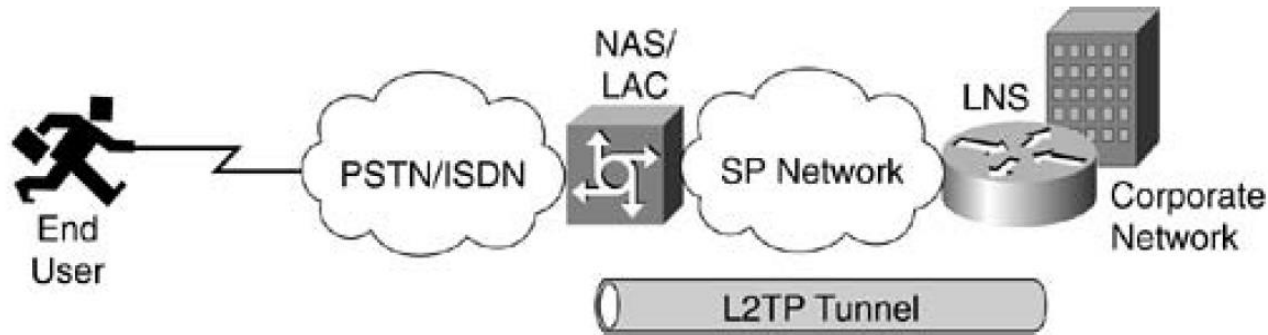
Características de una VPN

- El tráfico VPNs debe ser encriptado, para no ser accedido en su tránsito por la Internet pública
- Las VPNs deben estar autenticadas
- Esta autenticación puede ser manual, o puede estar integrada en algún esquema global (IKE, PKI, Kerberos, ...)
- No puede alterarse la VPN una vez establecida
- Todos los componentes de la VPN deben acordar y soportar las características de seguridad

Tipos de VPN

- **A nivel enlace (L2TP, PPTP)**
- **A nivel red (IPSec, BGP MPLS)**
- **A nivel transporte (SSL)**
- **Cada aplicación dependerá del tipo de problema a resolver. Ejemplos**

VPNs de capa 2: L2TP o PPTP

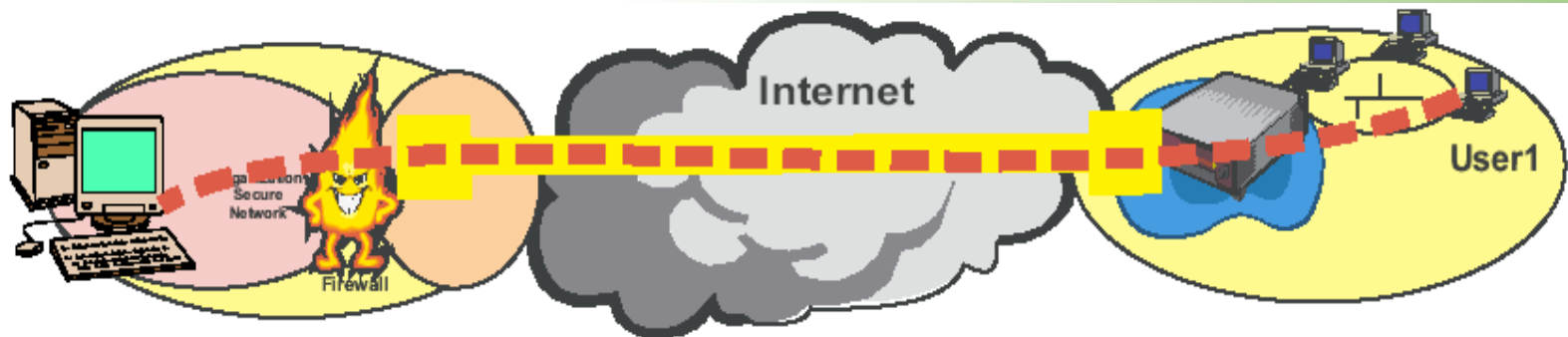


LAC: L2PT Acces Concentrator

L2PT

- L2TP: Tunnel Protocol de la capa 2. El PPP define un mecanismo de encapsulación para transportar los paquetes multiprotocolos a través de los enlaces punto a punto de la capa 2(L2). Típicamente, un usuario obtiene una conexión L2 a un servidor de acceso a la red(NAS) usando una técnica tal como Servicio telefónico sencillo antiguo (POTS) de marcado manual, ISDN o Asymmetric Digital Subscriber Line (ADSL). El usuario entonces ejecuta el PPP sobre esa conexión. En tal configuración, la punta de terminación L2 y el punto final de la sesión PPP residen en el mismo dispositivo físico (el NAS).L2TP amplía el modelo PPP al permitir que los puntos finales de L2 y de PPP residan en distintos dispositivos interconectados por una red. Con el L2TP, el usuario tiene una conexión L2 a un concentrador de acceso, y el concentrador entonces hace un túnel las tramas individuales PPP al NAS. Esto permite el procesamiento real de los paquetes PPP para separarse de la terminación del circuito de L2.
- L2F: Layer 2 Forwarding Protocol. L2F es un protocolo de tunelización más antiguo al L2TP.
- LAC: L2TP Access Concentrator. Un nodo que actúa como un lado de un punto final del túnel L2TP y es un par al LNS. El LAC se sienta entre un LNS y un cliente y adelante los paquetes a y desde cada uno. Los paquetes se envían desde el LAC hacia el LNS requieren una tunelización con el protocolo L2TP. La conexión del LAC al cliente está típicamente con el ISDN o el análogo.
- LNS: L2TP Network Server. Un nodo que funciona como un costado de un punto final de un túnel L2TP y es un par para el LAC.
- El LNS es el punto de terminación lógico de una sesión PPP que está siendo tunelizada desde el cliente por el LAC.
- Gateway de inicio: Iguales definiciones que LNS en la terminología de L2F. NAS : Iguales definiciones que LAC en la terminología de L2F. Túnel: En la terminología L2TP, un túnel existe entre un par LAC-LNS. El túnel consiste en un control de conexión y cero o más sesión L2TP. El túnel lleva los datagramas PPP y los mensajes encapsulados del control entre el LAC y el LNS. El proceso es el mismo que se aplica al L2F.
- Sesión: El L2TP está orientado a la conexión. LNS y LAC mantienen un estado para cada llamada que se inicia o responde a través de LAC. Una sesión L2TP se crea entre el LAC y el LNS cuando una conexión PPP de punta a punta se establece entre un cliente y el LNS. Los datagramas relacionados con la conexión PPP se envían sobre el túnel entre el LAC y el LNS. Hay una relación uno a uno entre las sesiones establecidas L2TP y sus llamadas asociadas. El proceso es el mismo que se aplica al L2F.

VPNs basadas en IPSec



Builds the tunnel

Integrated security technologies

ESP = Encapsulating Security Payloads - encrypts IP datagram

DES and 3DES are most common encryption mechanisms used

May provide confidentiality, authentication, integrity, non-repudiation, replay protection, and traffic analysis protection

Does everything AH does

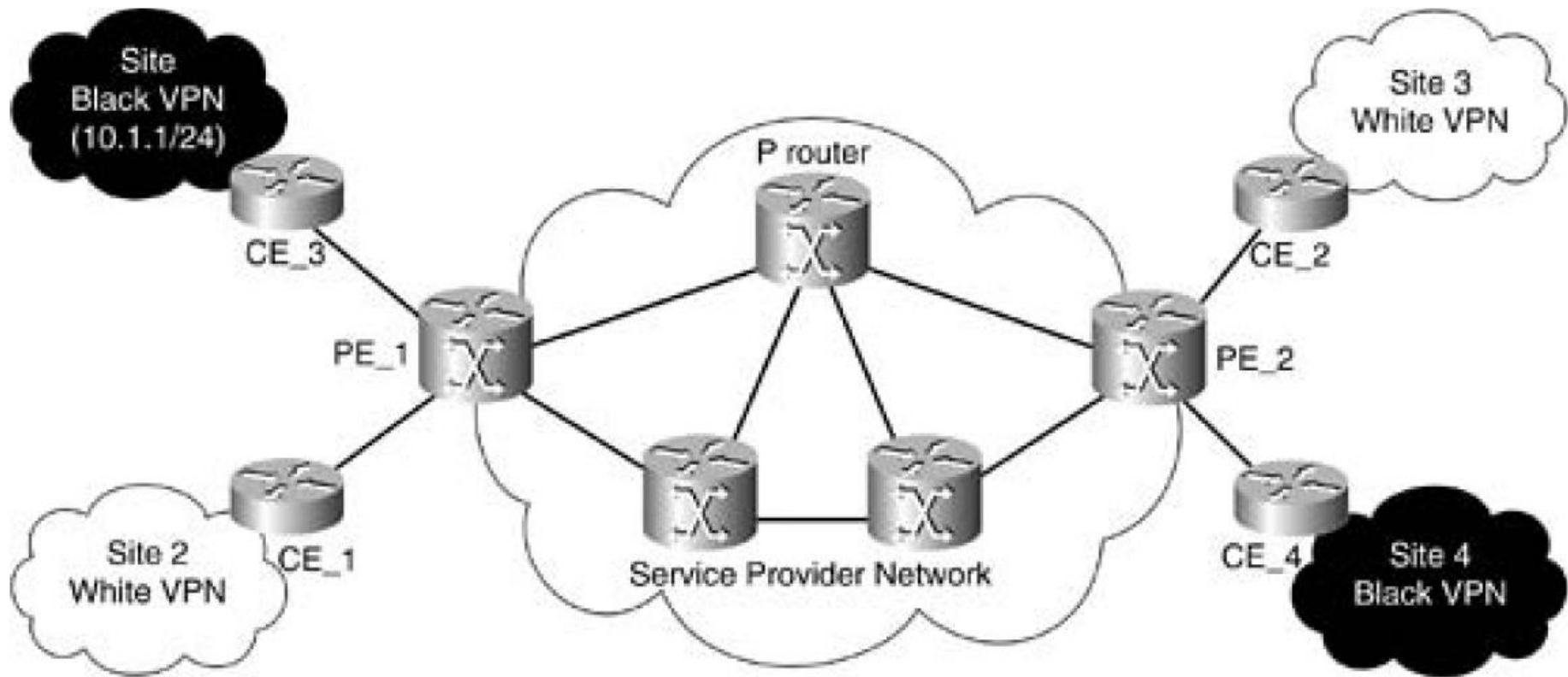
AH = Authentication Header - validates sender and indicates data integrity

MD5 and SHA1 are most common authentication mechanisms used

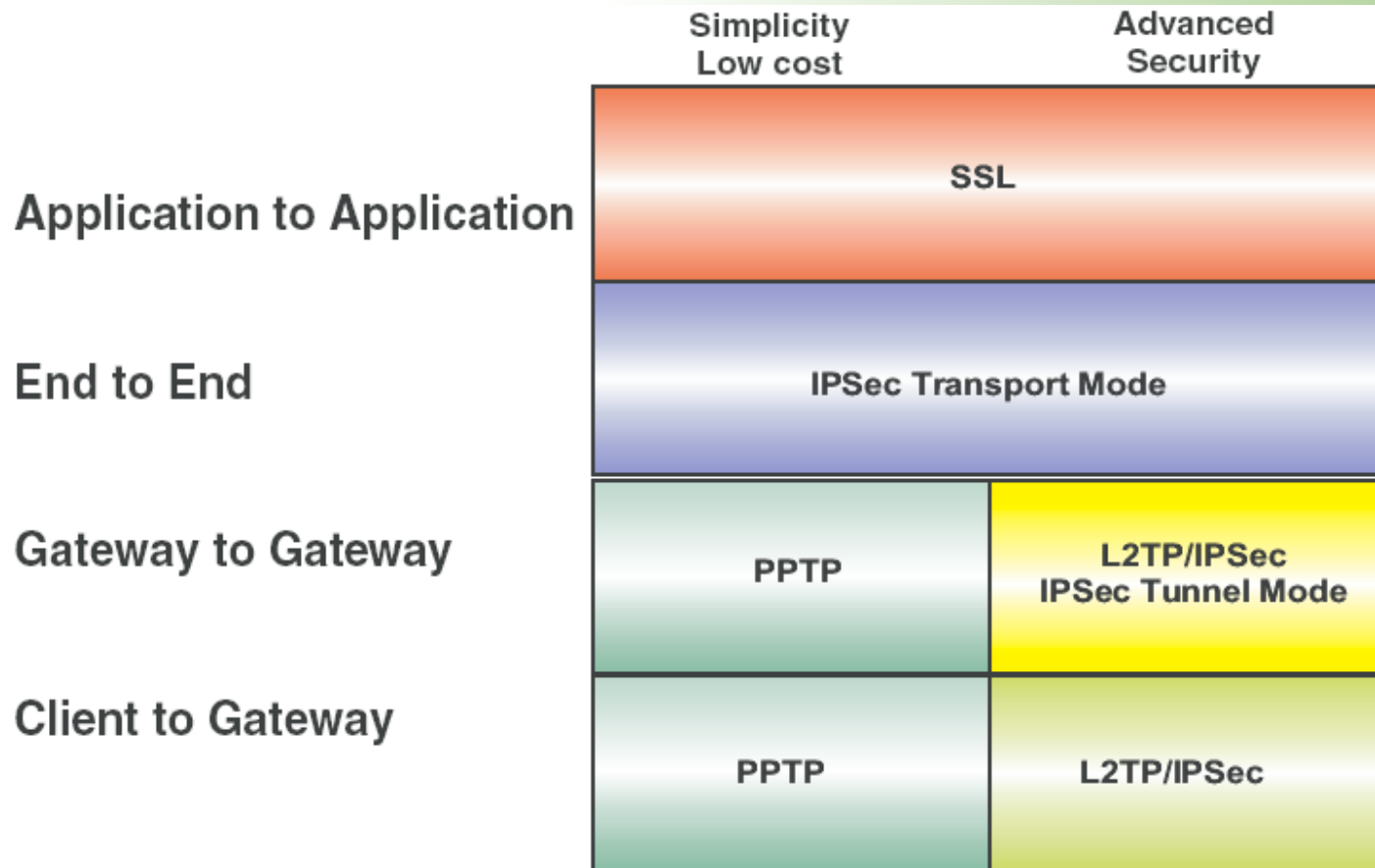
Provides integrity and authentication but not confidentiality

IKE - Internet Key Exchange (aka:ISAKMP/Oakley) Protocol

VPNs basadas en BGP/MPLS



VPNs – Distintas tecnologías



PPTP - Point to Point Tunneling Protocol - Layer 2 - Multiprotocol

L2TP/IPSec - Layer 2 Tunneling Protocol - Multiprotocol - Encryption and Authentication

IPSec - IP Security - Layer 3 - IP protocol - Encryption and Authentication

SSL - Secure Sockets Layer - Layer 6/7 - Application - Encryption and Authentication

VPNs: comparación

	L2TP/IPSec	IPSec	PPTP	SSL
Mode	Client/server	Host-host	Client/server	Client/server
Layer	2	3	2	7
Protocols	Multiprotocol	IP	Multiprotocol	IP
Security				
User Authentication	PKI		PKI	Log-in
Machine Authentication		PKI		
Packet Authentication		X	X	
Packet Encryption	DES, 3DES, PGP	DES, 3DES	X	
Key Management	IKE	IKE	PKI	Private Key
*Provided outside of specification				

VPNs: relación con NAT

- Se pueden utilizar las VPNs junto con un mecanismo de direcciones privadas (NAT)
- Se necesitan mantener TABLAS en los routers para encontrar las direcciones a través del túnel
- Distintas variantes (NAT, NAT/PAT, ...)



FUNCIONAMIENTO DE NAT

PAQUETE ENVIADO	
IP Origen	192.168.1.20
Puerto Origen	5674
IP Destino	67.54.3.67
Puerto Destino	80

El router modifica:

- *IP Origen*: Cambia la IP privada por la IP Pública
- *Puerto de origen*: Inserta uno al azar y que no esté en uso.



PAQUETE RECIBIDO	
IP Origen	65.87.5.33
Puerto Origen	9000
IP Destino	67.54.3.67
Puerto Destino	80

PAQUETE RECIBIDO	
IP Origen	67.54.3.67
Puerto Origen	5674
IP Destino	192.168.1.20
Puerto Destino	80

El router modifica:

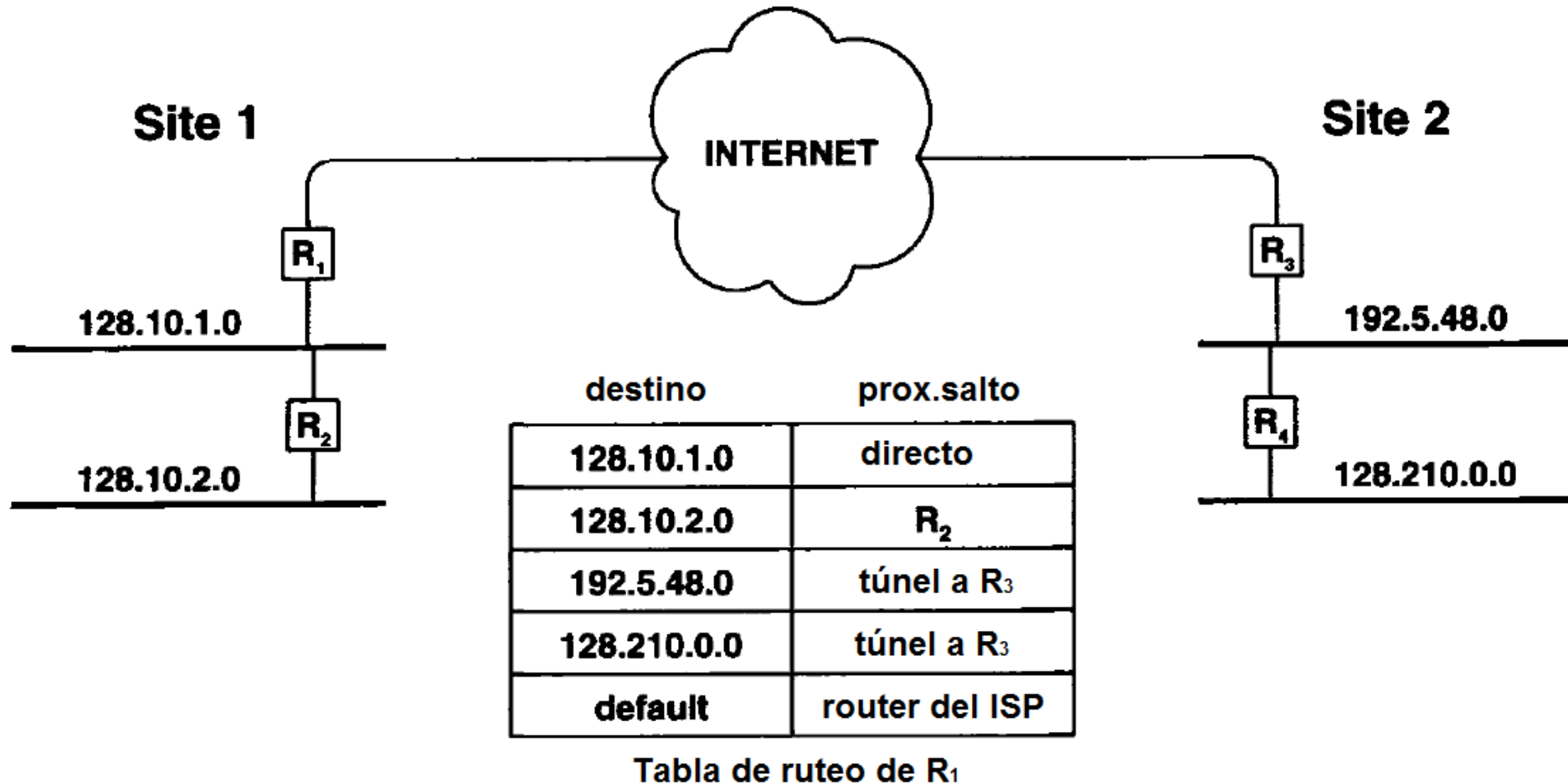
- *IP Origen*: Cambia la IP Pública por la IP Privada correspondiente según la tabla de reenvío.
- *Puerto de destino*: Cambia el puerto de destino por el correspondiente según la tabla de reenvío.



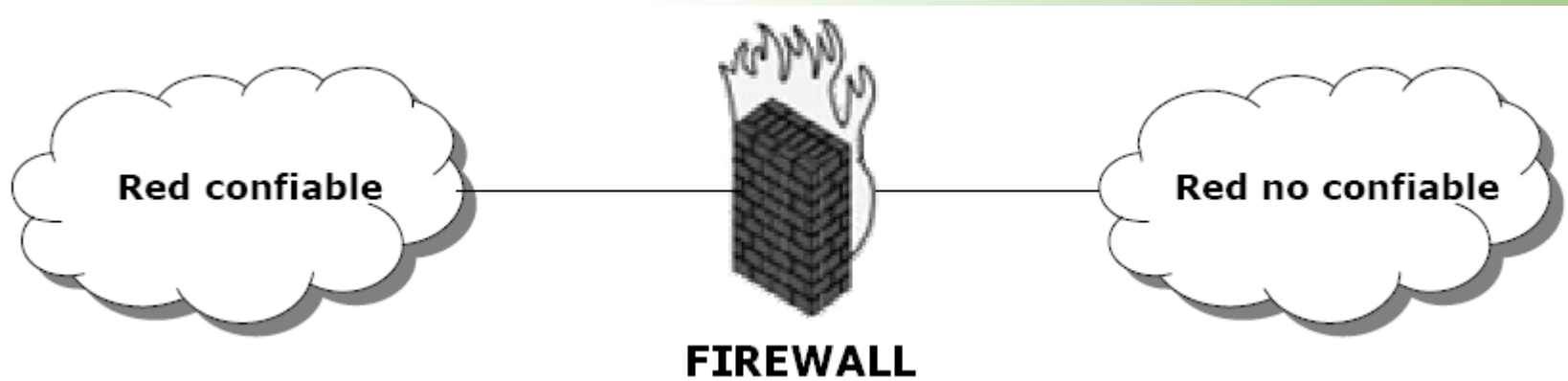
PAQUETE ENVIADO	
IP Origen	67.54.3.67
Puerto Origen	80
IP Destino	65.87.5.33
Puerto Destino	9000

Tabla de reenvío			
Red Interna		Red Externa	
IP Privada	Puerto	IP Destino	Puerto
192.168.1.20	5674	67.54.3.67	9000

VPNs: relación con NAT



Firewalls

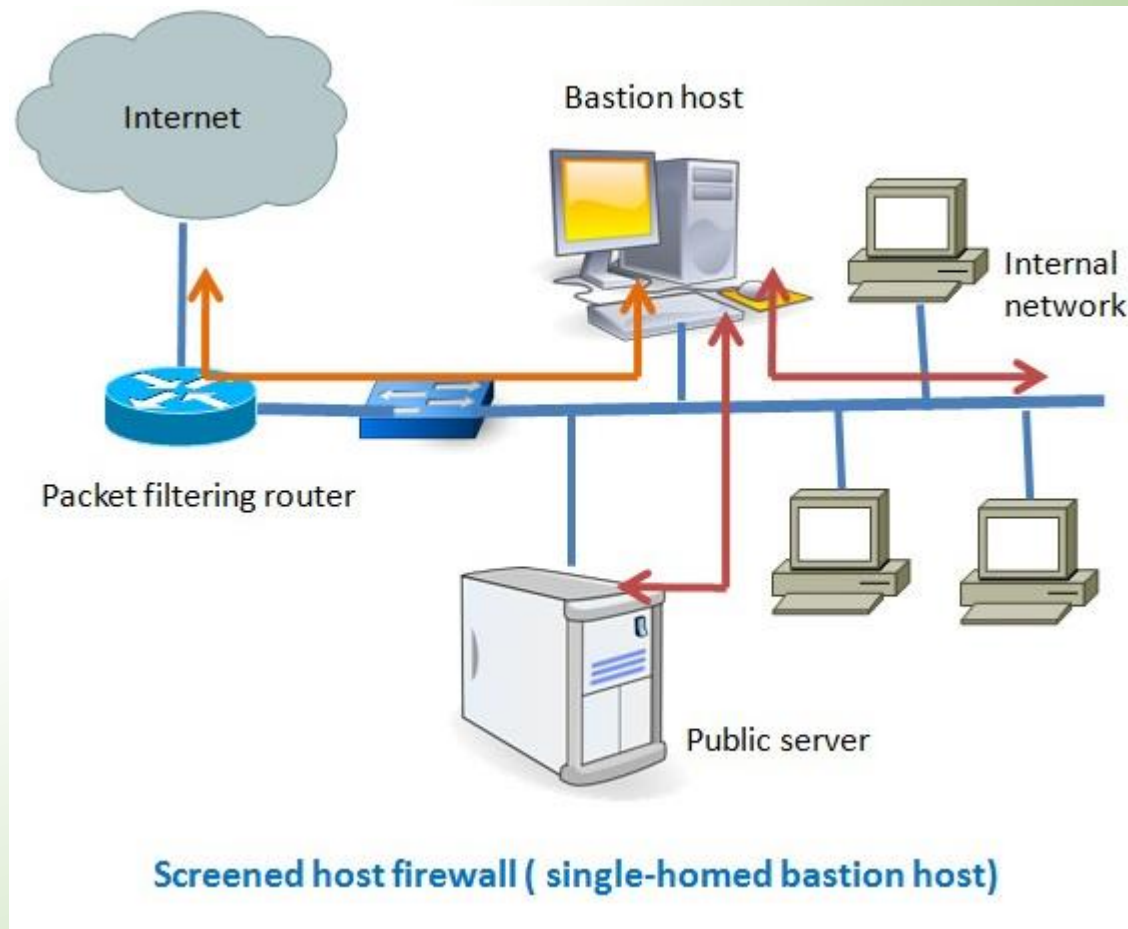


- Dispositivo que aísla redes, controlando y filtrando el tráfico
- Inspeccionan cada paquete, decidiendo si dejarlo pasar o descartarlo (silent drop)
- Se pueden utilizar en diferentes configuraciones
- Basados en hard o en soft (iptables, ipchains)
- Pueden estar integrados en los routers, aunque también pueden ser dispositivos separados
- Componente ESENCIAL para una red segura

Firewalls – 1a generación

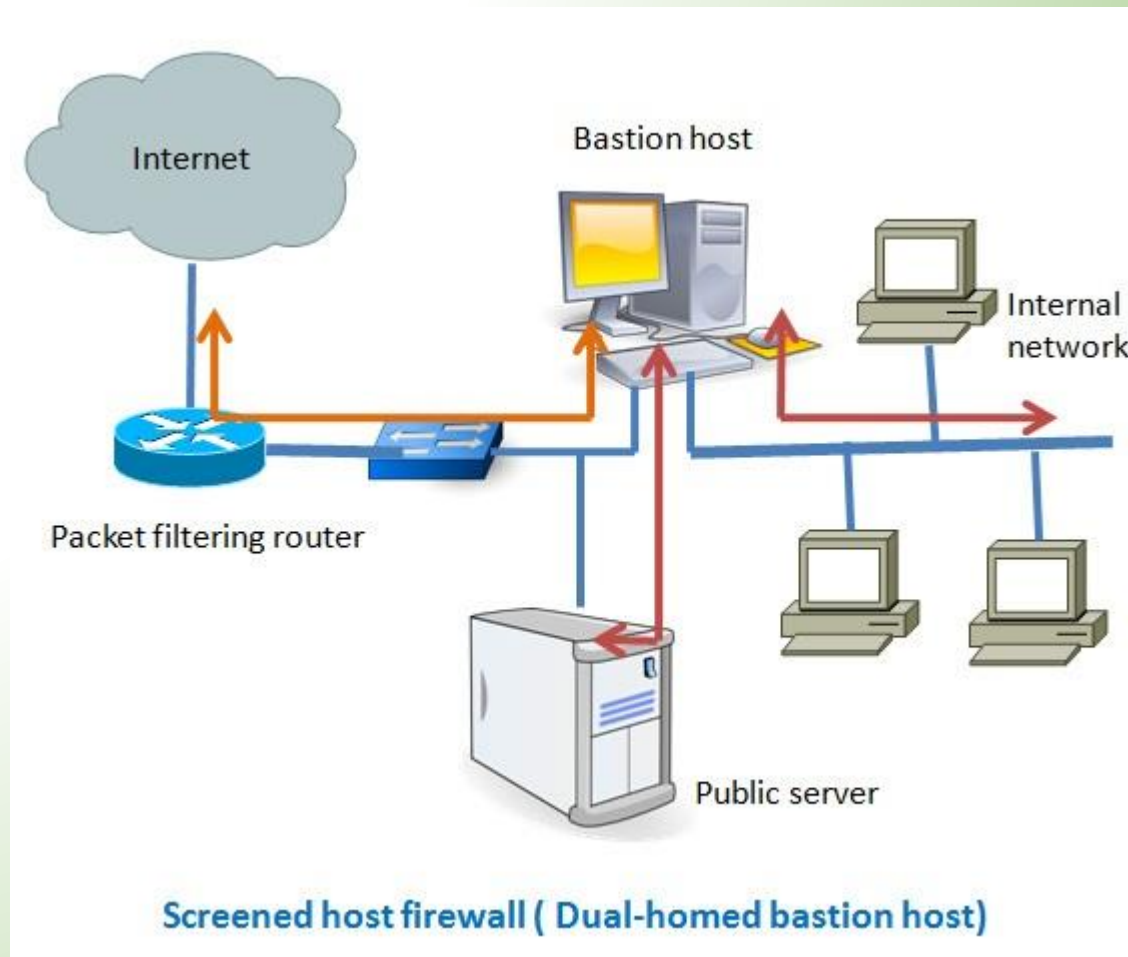
- También conocidos como filtros de paquetes o “screening router”
- Muchas veces implementados en los routers mediante ACLs
- Pueden filtrar por IP origen/destino, y por puerto TCP/UDP
- Son los más rudimentarios, y a la vez los más estrictos
- Presentan poca flexibilidad y son difíciles de mantener y actualizar
- Stateless – no mantienen registro de los flujos y procesan cada paquete individualmente

Firewalls – Escenarios



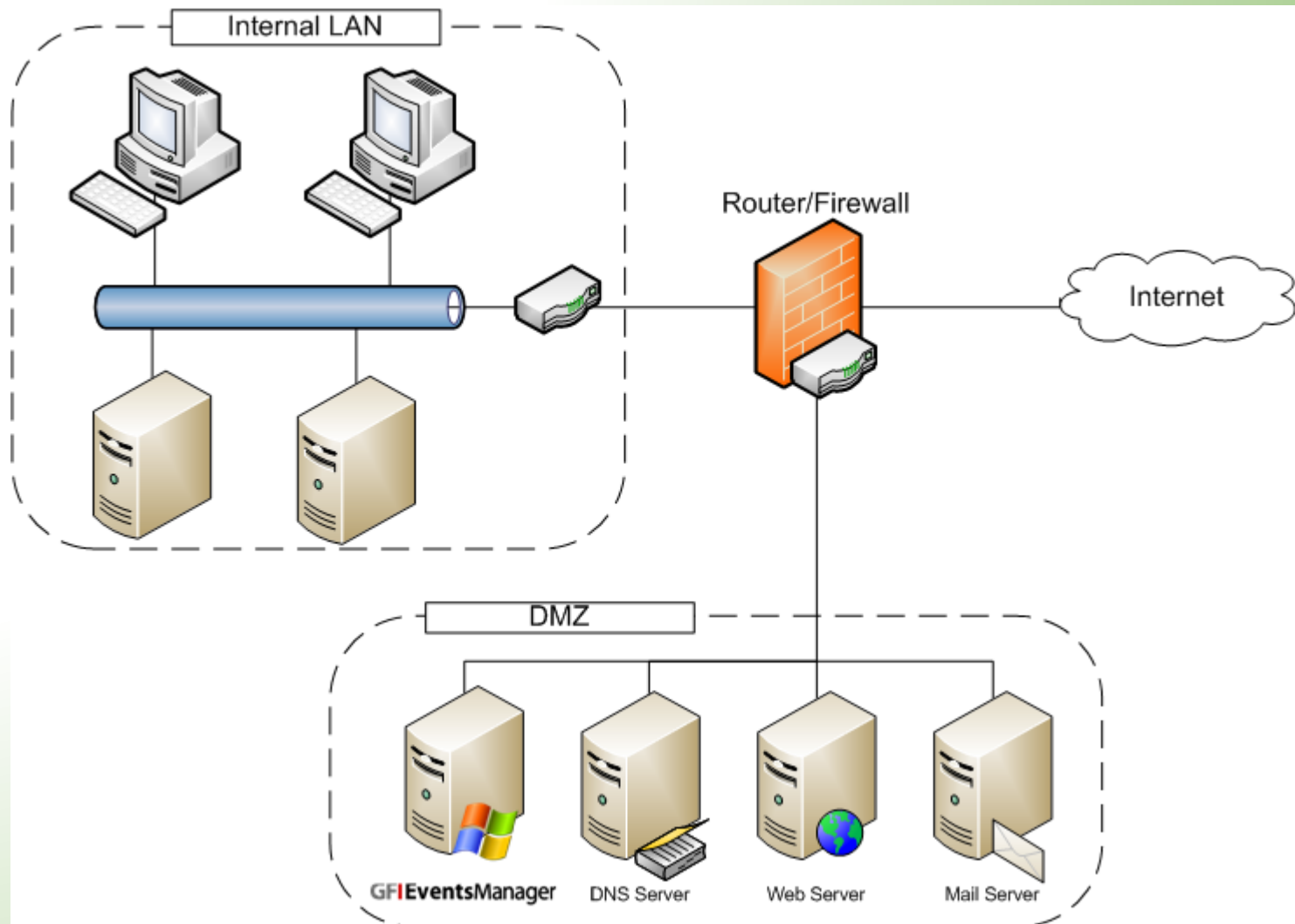
Screened host

Firewalls – Escenarios



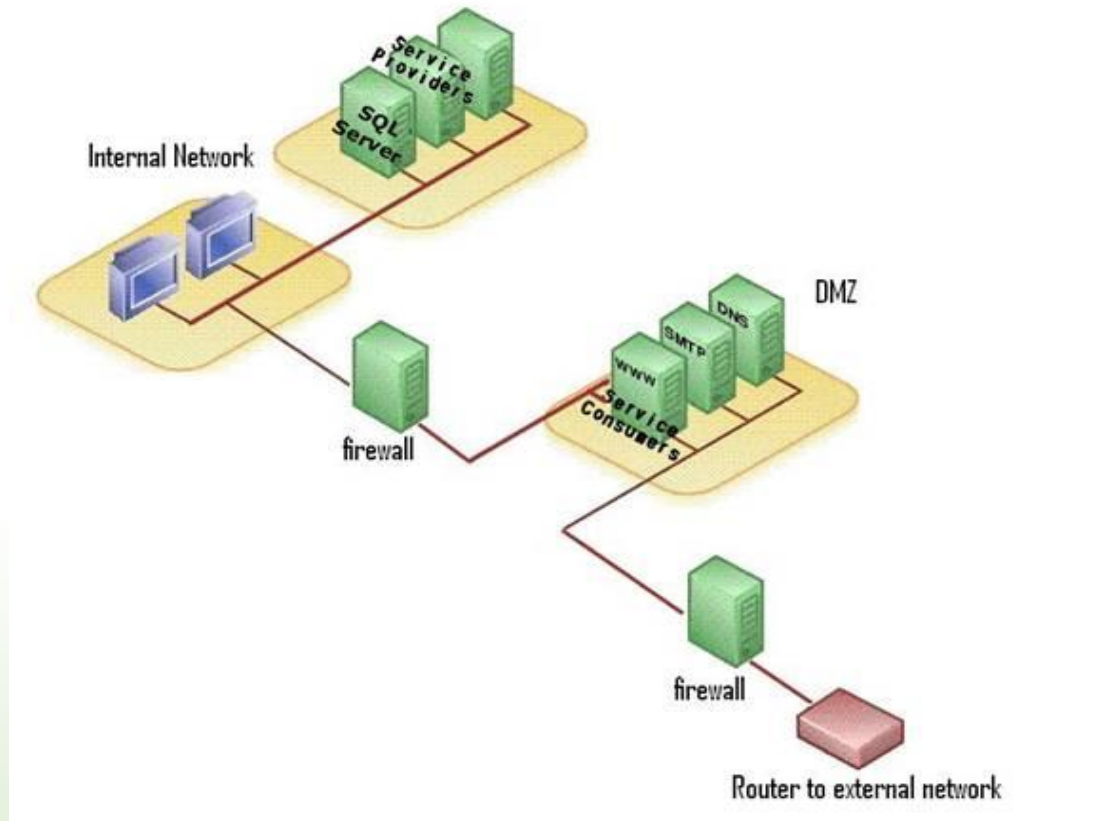
Dual homed

Firewalls – DMZ



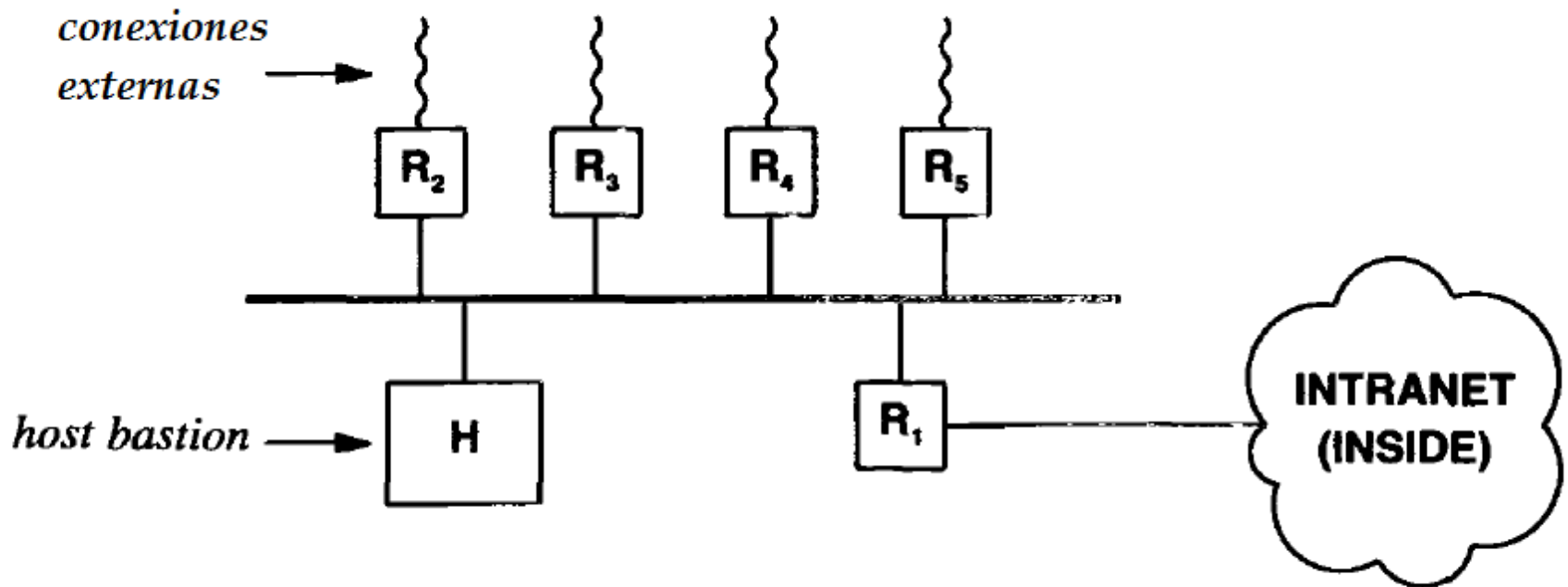
- Permite situar los servidores accesibles desde el exterior (Web, Mail,...)
- A la vez que aislar los servidores internos

DMZ y doble Firewall



- Mayor aislamiento de la red interna
- Más flexibilidad para configurar seguridad
- Exige mayor grado de configuración y gestión

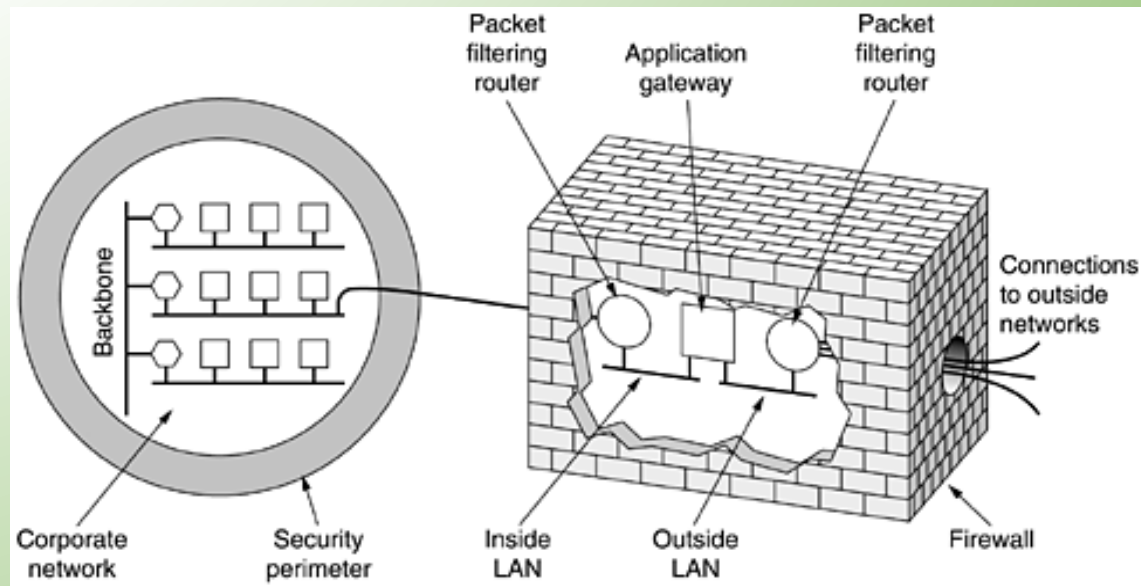
Firewall para conexiones múltiples



- Evita flujos de pq no deseados entre conexiones
- Mayor redundancia
- Más flexibilidad para configurar seguridad
- Exige mayor grado de configuración y gestión

Firewalls – ALG

- Application Level Gateway. Combinan hard y soft
- Generalmente integrados en un PROXY
- Acepta paquetes por una interface, los examina y los reenvía
- Establece las conexiones en nombre del host (proxy) y puede examinar en detalle cada protocolo y conexión. Integran uno o más filtros de paquetes
- Problema: performance



Firewalls – Stateful inspection

- Los paquetes son inspeccionados completamente en tiempo real
- Se tiene en cuenta el flujo de paquetes previos y posteriores, y pueden detectar túneles
- Decodifican protocolos de capa superior
- Son actualizables
- Combinación hardware/software
- Pueden detectar patrones de comportamiento sospechoso, y reaccionar en consecuencia

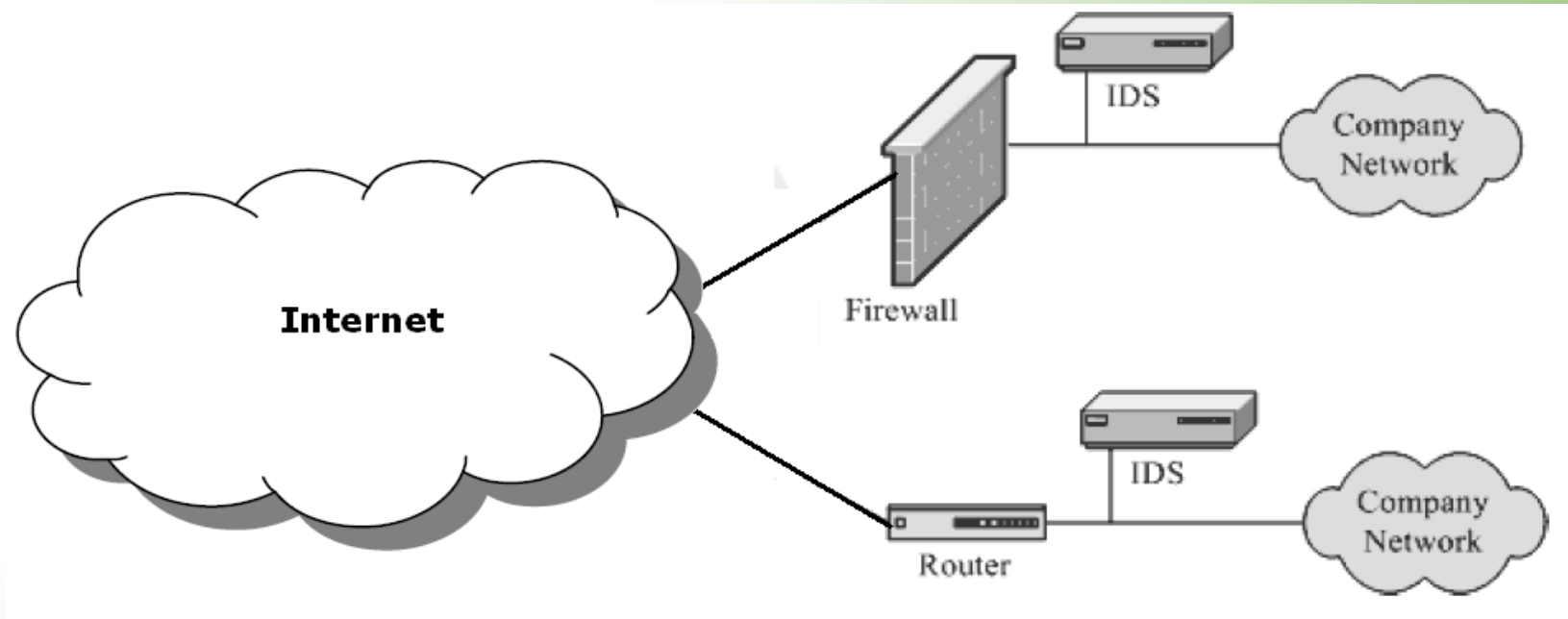
Dynamic packet inspection

- Se agrega la capacidad de modificar las reglas en forma dinámica y reaccionando al entorno

IDS – Intrusion Detection System

- Monitor de red. Por hard o soft (más común)
- Basado en la red (NIDS) o host (HIDS)
- “Escucha” todo el tráfico, en busca de patrones de comportamiento sospechosos u hostiles
- Muy útil en las primeras fases de un ataque (preparación y reconocimiento) o al final (información forense)
- Pueden generar alertas y/o registrar la información recolectada, para su posterior análisis (manual o automático)
- Además pueden actuar en forma reactiva (IPS)
- Integran uno o más sensores distribuidos
- Poseen motores de reconocimiento actualizables

Ubicación de los IDS/IPS



- Cerca de los recursos que queremos monitorear o proteger (ej. mismo segmento)
- Una alternativa son las "honey pots"

Comparación entre NIDS e HIDS

NIDS	HIDS
- No afectan al rendimiento de la red - Invisibles a los atacantes - Reconocen ataques dirigidos a varios dispositivos (p.ej. scans)	- Monitorean eventos locales - Pueden trabajar con datos encriptados - No son afectados por la red
- Pueden perder pq por sobrecarga - No informan si un ataque fue exitoso o no - No monitorean datos encriptados	- Captura específica al SO - Susceptible a ataques DoS - Afectan la performance del host

Existen dispositivos que integran varias funcionalidades en el mismo equipo (ej. Firewall + IDS + VPN + NAT +)

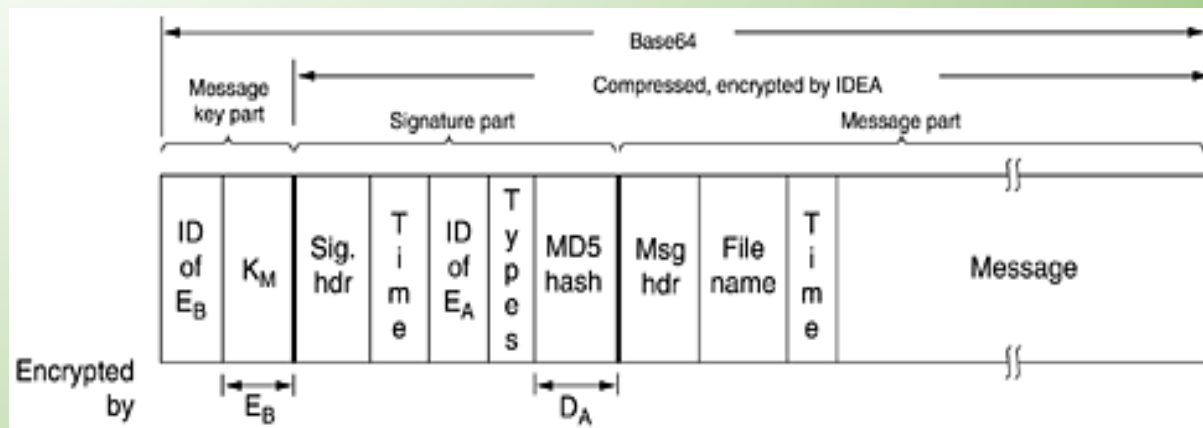
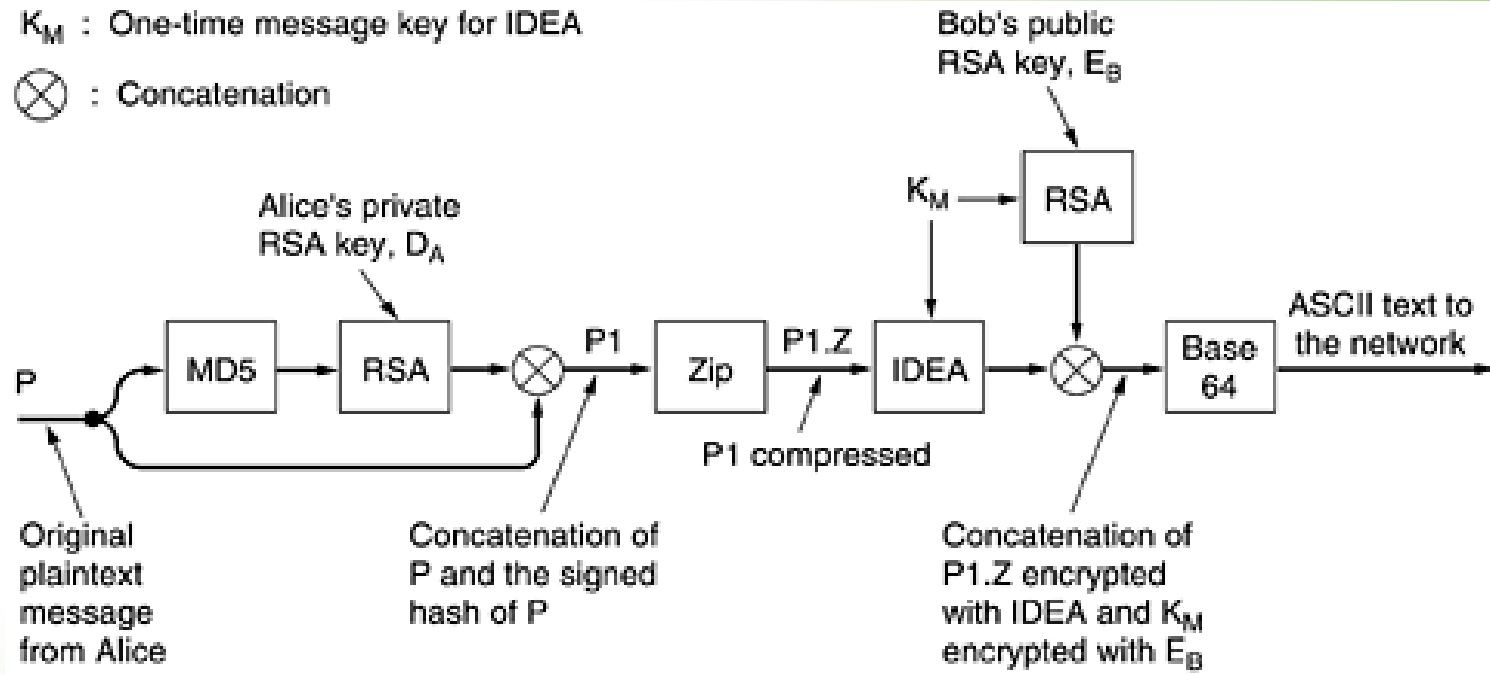
Seguridad a nivel aplicación - PGP

- Desarrollado por Phil Zimmermann en 1991
- Paquete de seguridad e-mail con encriptación, firma digital, autenticación, firma digital y compresión
- Distribuido gratuitamente.
- Fácil integración con clientes de correo comunes
- Dio origen a varias versiones (ej. Open PGP)
- Se basa en el algoritmo IDEA (simétrico).Pasos:
 - Calcula el hash
 - Lo firma con K_A
 - Concatena y comprime la firma y el mensaje
 - Aplica IDEA con una clave aleatoria K_M
 - Encripta la clave K_M con K_B
 - Concatena con clave y convierte a Base64
 - Envía $(K_M(msg).K_B(K_M))$

Seguridad a nivel aplicación - PGP

K_M : One-time message key for IDEA

$\otimes$: Concatenation



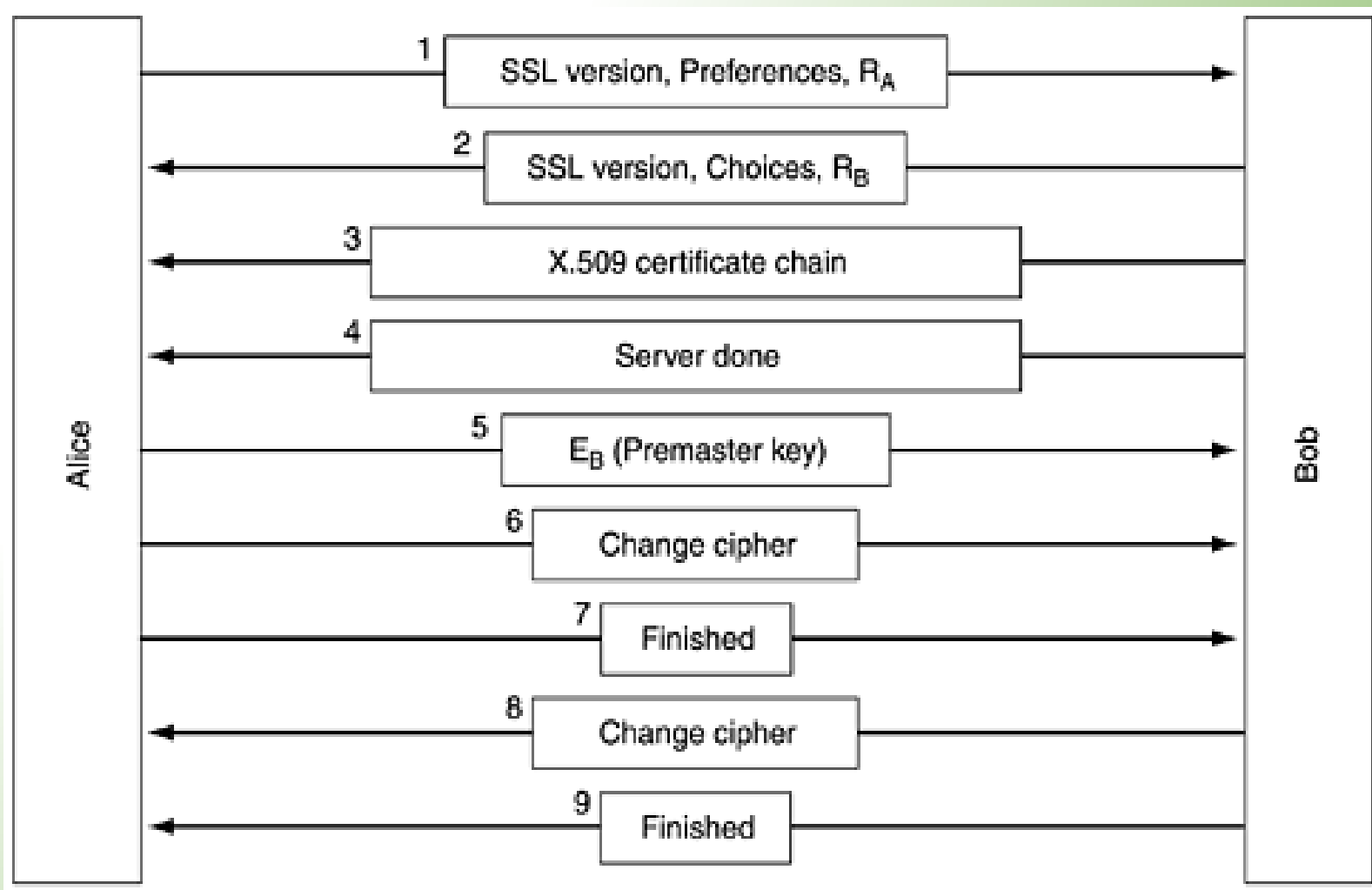
Seguridad a nivel aplicación - SSL

- Desarrollado para proteger la información en tránsito en la red
- Opera a nivel transporte. A partir de allí circula información encriptada
- Autentica ambos extremos y encripta los datos
- Independiente de otras estrategias de encriptación y autenticación en otras capas
- Permite negociar distintos parámetros (ej. algoritmos de encriptación, longitud de claves,...)
- Puede implementar también compresión
- Utiliza dos subprotocolos: Establecer y Transmitir
- Se basa en las claves públicas de cliente/servidor
- Pero usa una sola clave por sesión (simétrico)
- Utiliza certificados (PKI) y desafíos (R_A, R_B)

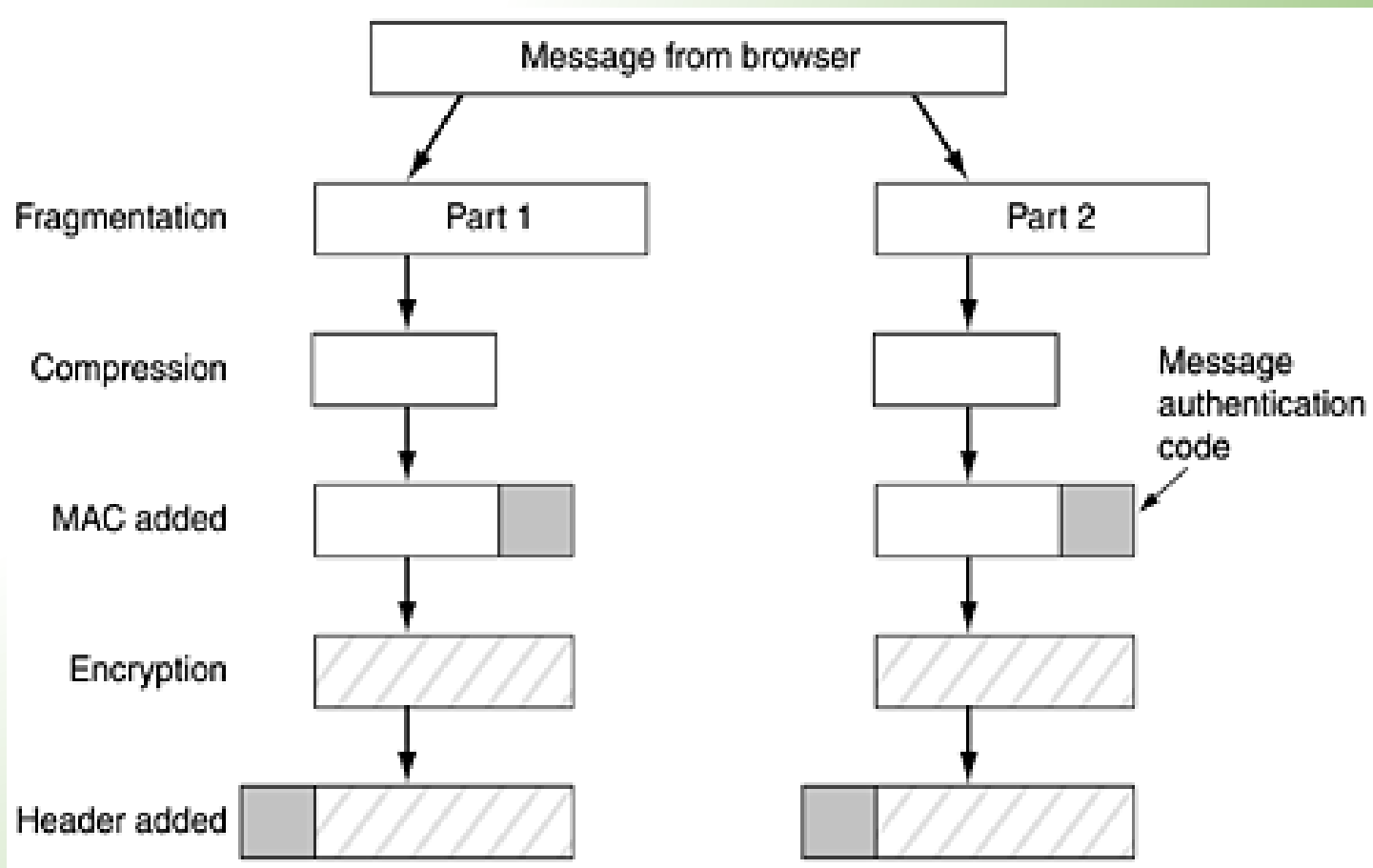
Seguridad a nivel aplicación - SSL

1. Saludo al cliente: Información que el servidor necesita para comunicarse con el cliente mediante SSL. Incluye el número de versión de SSL, configuración de cifrado y datos específicos de la sesión.
2. Saludo al servidor: Información que el servidor necesita para comunicarse con el cliente mediante SSL. Incluye el número de versión de SSL, configuración de cifrado y datos específicos de la sesión.
3. Autenticación y número secreto principal preliminar: El cliente autentica el certificado de servidor, por ejemplo nombre común / fecha / emisor. El cliente (según el tipo de cifrado) crea el número secreto principal preliminar de la sesión, cifra con la clave pública del servidor y envía el número secreto principal preliminar cifrado al servidor.
4. Descifrado y número secreto principal: El servidor utiliza su clave privada para descifrar el número secreto principal preliminar. El servidor y el cliente efectúan pasos para generar el número secreto principal con el cifrado acordado.
5. Cifrado con clave de sesión: El cliente y el servidor intercambian mensajes para informar de que se cifrarán futuros mensajes.

SSL – Establecimiento conexión



SSL – Transmisión



Ejemplos ataques y vulnerabilidades

Snooping/sniffing

Wireless cracking

ARP Spoofing/poisoning

MAC Address flooding

MITM

Crafted packet

Source routing

Ping of Death

Fragmentacion IP

Teardrop

Ataque por rebote

Port scanning (<> tipos ej SYN, SYNACK, RST, ...)

Fingerprinting

Secuestro TCP (Hi-jacking)

Prediccion nros secuencia TCP

DNS Poisoning/impersonating

DoS-DDoS

Buffer overrun/overflow

SQL Injection

Scripting

Backdoor

Gusanos

Trojanos

Spamming

Phishing

Exploits

Keyloggers

Virus/Malware/Spyware

Ataques a claves: diccionario, triviales, ...

Entonces...qué hacer!!!

- Integración de TODOS los componentes en una INFRAESTRUCTURA de seguridad
- Administración! (unidad 9) ej. desact.servicios. Costo \$0
- Mantenimiento y actualización – HW y SW.
- ANALISIS (para qué sirven los logs si nadie los mira?) y DOCUMENTACION (no inventar la rueda de nuevo)
- Backups!
- Antivirus!
- Conducir pruebas periódicas de seguridad y vulnerabilidades (NMAP, Nessus, ...)
- Consultar foros y sitios online

...si todo lo demás falla....

- Plan de contingencia
- Suspensión automática de servicios
- Contramedidas
- Escalabilidad respuesta
- CERT
- Plan Recuperación de Desastres
- Informática forense

Conceptos finales

- Muchas amenazas, muchas herramientas.
- Idea: niveles PROGRESIVOS y CRECIENTES de seguridad
- Clasificar las amenazas por probabilidad e impacto, y comenzar por lo más urgente
- Fijar POLITICAS de seguridad a nivel organización
- Nunca se tiene una red 100% segura, sólo distintos niveles de dolor!
- Ingeniería social (no subestimar el poder de la ignorancia)
- Tampoco el del acceso físico.
- Ej: trashing

Referencias

- **“Redes de Computadoras” - A.Tanenbaum Cap. 8**
- **Cisco ITH cap. 18 y cap. 52**
- **Comer 4a Ed. cap. 20 y cap. 32**
- **“Redes de Computadoras e Internet” - F.Halsall Cap. 10**
- **“Comunicaciones y Redes de Computadoras” - W. Stallings Cap. 18**
- **Material online (∞ ), por ej:**
- **<https://academy.bit2me.com/que-es-hash/>**
- **....No olviden todo el material del aula virtual**